DRAFT PROPOSAL TESIS UNTUK BIMBINGAN

TOPIK KERJA – JUDUL BELUM FINAL

Integrasi Cyber Threat Intelligence OpenCTI ke SEPSES Knowledge Graph dengan Provenance dan Validitas Waktu untuk Penilaian Kerentanan Berbasis Konteks Ancaman

DRAFT UNTUK BIMBINGAN

Versi: v3-draft-13 | Revisi: 9 Oktober 2026

Status: Belum disetujui pembimbing

Masalah, pertanyaan penelitian, ambang evaluasi, dan judul masih untuk didiskusikan.

Made Agastya

NIM

Pembimbing: Kabul Kurniawan, Ph.D.

Program Studi Magister Artificial Intelligence

Universitas Gadjah Mada

2026

RINGKASAN UNTUK BIMBINGAN

Draft ini mengusulkan satu masalah penelitian. SEPSES Knowledge Graph (Kiesling et al. 2019) dapat menemukan CVE yang memengaruhi aset sebuah organisasi, tetapi tidak dapat menjawab apakah, oleh siapa, terhadap sektor atau wilayah mana, dan kapan CVE tersebut dipakai dalam aktivitas ancaman. OpenCTI memuat konteks tersebut dalam format STIX 2.1, tetapi tidak menalar produk dan versi aset. Bila keduanya digabung tanpa memperhatikan waktu dan asal sumber, hampir separuh konteks ancaman menjadi keliru pada waktu keputusan. Pada data ekspor OpenCTI yang dimiliki, 45,8% asosiasi CVE–ancaman pada 30 September 2025 berasal dari laporan yang baru terbit sesudah tanggal itu. Pada 31 Desember 2025, 51,4% asosiasi sudah usang untuk jendela 90 hari.

Perubahan dari usulan pertemuan 1. Pada bimbingan pertama (18 Juni 2026) penulis mengusulkan atribusi APT *group* berbasis *knowledge graph*. Draft ini mengganti fokus tersebut dengan alasan yang dirinci pada Lampiran A (K0), tetapi tetap mengikuti alur kerja yang diarahkan pembimbing: *use case* dan CQ konkret, taksonomi, ontologi yang memakai ulang SEPSES, pemetaan, KG, kueri SPARQL, dan iterasi bila CQ belum terjawab. Kesesuaian setiap arahan dirangkum pada Lampiran C. Konteks aktor ancaman tidak dibuang; aktor tetap menjadi bagian konteks yang dijawab CQ3–CQ4.

Pertanyaan penelitian. Bagaimana CTI STIX 2.1 dari OpenCTI dapat diintegrasikan ke SEPSES Knowledge Graph sehingga pertanyaan penilaian kerentanan berbasis konteks ancaman pada aset organisasi dapat dijawab secara benar, dapat ditelusuri sumbernya, dan sesuai waktu keputusan?

Usulan. Penelitian memperluas kosakata dan pemetaan SEPSES/ICS-SEC (Kurniawan, Kiesling, Winkler, et al. 2024), yang saat ini memetakan STIX hanya untuk data ATT&CK statis, menjadi CTI operasional yang bertanggal. Perluasan ini mencakup laporan, korban sektor/negara, *provenance* per laporan (PROV-O), dan aturan keabsahan waktu bukti (*admissibility*) yang dapat dikueri per waktu t. Di atas KG terintegrasi tersebut, penelitian menyusun tier prioritas yang transparan dan dapat ditelusuri ke buktinya.

Evaluasi. Ukuran utamanya ada tiga:

(1) kebenaran jawaban *competency question* terhadap *gold standard*;

(2) proporsi jawaban yang memakai bukti di luar waktu keputusan, dibandingkan dengan integrasi naif;

(3) kelengkapan jejak *provenance*.

Studi kasus kegunaan bagi analis menjadi pelengkap.

Hasil pendahuluan. Selain profil data, alur kerja tersebut sudah dicoba pada sampel kecil (7 laporan, 3 CVE, 5 aset skenario). KG berukuran 4.739 *triple* disimpan di Apa-

che Jena Fuseki. CQ1, CQ3, CQ4, CQ5, dan CQ7 sudah terjawab, CQ2 dan CQ6 baru sebagian, dan CQ8 belum dicoba (Subbab 4.9.2).

Yang tidak diklaim. Penelitian ini tidak mengklaim ranking lebih akurat daripada EPSS/KEV, tidak memprediksi eksploitasi, dan tidak membangun ontologi keamanan universal.

Yang diminta dari pembimbing. Keputusan atas daftar pada Lampiran A, terutama ruang lingkup masalah, pola *provenance* (RDF-star atau *named graph*), bahasa implementasi pemetaan, sumber data, dan ambang evaluasi.

DAFTAR ISI

Ringkasan untuk Bimbingan i
DAFTAR ISI iii
BAB I Pendahuluan 1
1.1 Latar Belakang 1
1.2 Rumusan Masalah 5
1.3 Batasan Masalah 6
1.4 Tujuan Penelitian 7
1.5 Manfaat Penelitian 7
1.5.1 Manfaat Akademik 7
1.5.2 Manfaat Praktis 8
1.6 Definisi Operasional Istilah 8
1.7 Sistematika Penulisan 9
BAB II Tinjauan Pustaka 11
2.1 Metode Tinjauan 11
2.2 *Knowledge Graph* Keamanan Siber dan Kerentanan 12
2.3 Ontologi dan *Knowledge Graph* CTI 13
2.4 Kualitas, *Provenance*, dan Waktu CTI 14
2.5 Prioritisasi Kerentanan Berbasis Konteks 15
2.6 Matriks Perbandingan 16
2.7 *Gap* Penelitian 17
2.8 Posisi Penelitian terhadap Karya Terdekat 18
BAB III Landasan Teori 21
3.1 *Knowledge Graph*, RDF, dan *Named Graph* 21
3.1.1 Model data RDF 21
3.1.2 RDF *dataset* dan *named graph* 22
3.2 Ontologi dan Rekayasa Ontologi Berbasis *Competency Question* 22
3.2.1 Ontologi dan OWL 2 22
3.2.2 Rekayasa ontologi berbasis CQ 23
3.2.3 Validasi ontologi dengan OOPS! 23
3.3 Kosakata SEPSES dan ICS-SEC 24
3.4 STIX 2.1 dan OpenCTI 25
3.4.1 Model objek dan relasi STIX 2.1 25
3.4.2 OpenCTI sebagai sumber data 26
3.5 *Provenance*: PROV-O dan Pola Representasi Pernyataan 26
3.5.1 PROV-O 26
3.5.2 Dua pola mengaitkan metadata dengan pernyataan 26

3.6 Waktu dan Keabsahan Bukti (*Admissibility*) 27
3.6.1 Tiga jenis waktu 27
3.6.2 Definisi formal 28
3.7 Validasi Data dengan SHACL 29
3.8 *Exposure* Aset 30
3.8.1 CPE 2.3 dan rentang versi 30
3.8.2 Logika tiga nilai 30
3.9 Tabel Keputusan Prioritas dan Sinyal Pembanding 31
3.9.1 SSVC sebagai model keputusan 31
3.9.2 KEV, CVSS, dan EPSS 31
3.10 Teori Evaluasi 32
3.10.1 *Precision*, *recall*, dan F1 untuk jawaban kueri 32
3.10.2 F1 makro 32
3.10.3 Selang kepercayaan *bootstrap* 32
3.10.4 Cohen's κ 33
3.11 Hubungan Teori dengan Rancangan Penelitian 33
BAB IV Metode dan Rancangan Penelitian 35
4.1 Jenis dan Pendekatan Penelitian 35
4.2 Analisis Kebutuhan Penelitian 36
4.2.1 Kebutuhan Data 36
4.2.2 Infrastruktur Akuisisi Data: OpenCTI berbasis Docker 37
4.2.3 Kebutuhan Perangkat 39
4.2.4 Kebutuhan Pengujian dan Evaluasi 40
4.3 Bagan Alir Penelitian 40
4.4 Rancangan Ontologi dan Integrasi 42
4.4.1 Penggunaan Ulang Kosakata SEPSES/ICS-SEC 42
4.4.2 Perluasan Pemetaan `cat-json.rml` 43
4.4.3 Entity Linking 44
4.4.4 *Provenance* per Laporan 45
4.5 Competency Questions 45
4.5.1 Contoh Terapan: CVE-2025-8088 46
4.6 Rancangan Penalaran 47
4.6.1 *Exposure* Aset 48
4.6.2 Keabsahan Waktu Bukti (*Admissibility*) 48
4.6.3 Tier Prioritas Transparan 48
4.7 Desain Eksperimen 49
4.7.1 Skenario Pembanding 49
4.7.2 Titik Waktu dan Jendela Kebaruan 49
4.7.3 *Gold Standard* 49

4.8 Validation, Testing, dan Evaluation 50
4.9 Hasil Pendahuluan 52
4.9.1 Realitas Data OpenCTI 52
4.9.2 Prototipe KG v0.1 pada Sampel Kecil 52
4.9.3 Artefak Pekerjaan Pendahuluan 53
4.10 Ancaman Validitas dan Etika 53
4.11 Jadwal Penelitian 54
DAFTAR PUSTAKA 58
LAMPIRAN A Daftar Keputusan untuk Bimbingan 64
LAMPIRAN B Matriks Keterlacakan 68
LAMPIRAN C Kesesuaian dengan Arahan Bimbingan Pertemuan 1 69

BAB I
PENDAHULUAN

1.1 Latar Belakang

Manajemen kerentanan merupakan salah satu kegiatan pokok keamanan siber di organisasi. Setiap kerentanan perangkat lunak yang diumumkan secara publik diberi pengenal *Common Vulnerabilities and Exposures* (CVE). Tim keamanan kemudian harus memutuskan kerentanan mana yang menyentuh aset mereka dan mana yang perlu ditambal (*patch*) lebih dahulu. Jumlah CVE yang harus dicermati terus bertambah: profil yang dilakukan dalam penelitian ini terhadap repositori CVE List v5 mencatat 90.255 berkas rekaman CVE untuk tahun 2025–2026 saja. Sebaliknya, kapasitas organisasi untuk menguji dan memasang *patch* dibatasi oleh jendela pemeliharaan, ketergantungan layanan, dan jumlah personel **[Diskusi: rujukan: data kapasitas remediasi/*patch* organisasi]**. Karena tidak semua kerentanan dapat ditangani sekaligus, pertanyaan yang sebenarnya dihadapi analis bukan lagi "kerentanan apa yang ada", melainkan "kerentanan mana pada aset saya yang paling perlu ditangani sekarang, dan atas dasar bukti apa".

Beberapa sumber dan metode telah dikembangkan untuk membantu keputusan tersebut:

- *Common Vulnerability Scoring System* (CVSS) mengukur keparahan teknis suatu kerentanan (Forum of Incident Response and Security Teams 2019).
- *Exploit Prediction Scoring System* (EPSS) memberikan peluang eksploitasi berbasis data untuk setiap CVE (Jacobs, Romanosky, Edwards, et al. 2021; Jacobs, Romanosky, Suciu, et al. 2023).
- Katalog *Known Exploited Vulnerabilities* (KEV) dari CISA mendaftar CVE yang terbukti telah dieksploitasi (Cybersecurity and Infrastructure Security Agency 2026). Katalog ini menjadi acuan kewajiban remediasi bagi instansi federal Amerika Serikat (Cybersecurity and Infrastructure Security Agency 2021).
- *Stakeholder-Specific Vulnerability Categorization* (SSVC) menawarkan tabel keputusan yang menyesuaikan prioritas dengan sudut pandang pemangku kepentingan (Spring et al. 2019).

Kombinasi sinyal tersebut juga telah dievaluasi dalam skala besar. Misalnya, Shimizu and Hashimoto (2026) merangkai KEV/EPSS dan CVSS dalam pohon keputusan dua tahap dan mengujinya pada 28.377 CVE.

Di sisi representasi pengetahuan, SEPSES *Knowledge Graph* (Kiesling et al. 2019) mengintegrasikan beberapa sumber kerentanan ke dalam satu *knowledge graph* (KG): CVE; CVSS; *Common Platform Enumeration* (CPE), yaitu penamaan baku

produk perangkat lunak; *Common Weakness Enumeration* (CWE), yaitu jenis kelemahan; dan *Common Attack Pattern Enumeration and Classification* (CAPEC), yaitu pola serangan. KG tersebut dibangun dengan RDF, model data yang menyatakan pengetahuan sebagai *triple* subjek–predikat–objek, dan dapat dikueri dengan SPARQL. SEPSES juga mendemonstrasikan penilaian kerentanan berbasis aset: perangkat lunak pada aset yang dimodelkan melalui CPE dapat dihubungkan ke daftar CVE yang memengaruhinya. Pola ini kemudian diperluas oleh ICS-SEC KG ke domain sistem kendali industri, termasuk pemetaan data MITRE ATT&CK dari format STIX ke kosakata (*vocabulary*) SEPSES (Kurniawan, Kiesling, Winkler, et al. 2024). Dengan demikian, sudah tersedia fondasi semantik yang matang untuk menalar hubungan aset, produk, dan kerentanan secara terstruktur.

Meskipun demikian, solusi-solusi tersebut belum menjawab pertanyaan analis secara utuh. CVSS bersifat statis dan cenderung menghasilkan terlalu banyak prioritas tinggi (Shimizu and Hashimoto 2026), dan berbagai sistem skor dapat memberikan keputusan yang saling bertentangan untuk CVE yang sama (Koscinski et al. 2025). EPSS memberikan peluang eksploitasi yang bersifat global, sedangkan KEV hanya menyatakan secara biner bahwa suatu CVE "pernah dieksploitasi". Tidak satu pun yang menyatakan *siapa* yang memakai kerentanan itu, *dengan teknik apa*, *terhadap sektor atau wilayah mana*, dan *seberapa baru* aktivitas tersebut. SEPSES hanya memuat data kerentanan; KG ini tidak memiliki konsep aktor ancaman, kampanye, atau sektor sasaran (Kiesling et al. 2019). Pemetaan ATT&CK pada ICS-SEC KG memang menambahkan teknik dan perangkat lunak serangan, tetapi sebagai data referensi statis, bukan sebagai laporan aktivitas ancaman yang bertanggal (Kurniawan, Kiesling, Winkler, et al. 2024).

Ilustrasi. Misalkan sebuah instansi pemerintah memakai WinRAR 7.10 pada komputer kerjanya. Pada 8 Agustus 2025 terbit CVE-2025-8088, kerentanan WinRAR versi ≤ 7.12 yang empat hari kemudian masuk katalog KEV. Dengan SEPSES saja, analis dapat mengetahui keparahan dan jenis kelemahannya, tetapi rekaman CVE ini tidak memiliki CPE eksplisit, sehingga kecocokannya dengan aset pun harus ditentukan dari rentang versi. Informasi tersebut menjawab "seberapa parah" kerentanan ini, tetapi tidak menjawab pertanyaan yang lazim diajukan analis sebelum menetapkan prioritas:

(a) apakah ada aktor atau *malware* yang dilaporkan memakai CVE ini;
(b) apakah aktor tersebut menyasar sektor pemerintahan atau wilayah tempat instansi berada;
(c) apakah laporan itu masih berlaku pada hari keputusan dibuat atau sudah usang;
(d) sejak kapan CVE ini tercantum di KEV;
(e) laporan, pembuat, dan tanggal mana yang dapat ditunjukkan sebagai dasar keputusan bila diaudit kemudian.

Data CTI milik peneliti menunjukkan bahwa jawabannya berubah menurut waktu. Hingga 30 September 2025, laporan yang menyebut CVE ini mengaitkannya dengan aktor RomCom dan sektor seperti Defense dan Finance, tetapi belum dengan sektor pemerintahan. Kaitan dengan sektor Government baru muncul dalam laporan 23 Oktober 2025 tentang aktor Bitter. Analis yang memutuskan pada akhir September dan analis yang memutuskan pada akhir Desember semestinya memperoleh jawaban berbeda, dan keduanya perlu dapat menunjukkan laporan yang menjadi dasarnya. Contoh ini diuraikan lengkap pada Subbab 4.5.1.

Jawaban atas pertanyaan-pertanyaan tersebut tersedia pada platform *cyber threat intelligence* (CTI). OpenCTI menyimpan CTI dalam format *Structured Threat Information Expression* (STIX) 2.1 (Jordan et al. 2021), termasuk relasi antara kerentanan, aktor (*intrusion-set*), *malware*, teknik serangan, dan sasaran. Analisis pendahuluan atas ekspor OpenCTI milik peneliti, yang datanya diimpor melalui konektor (*connector*) AlienVault, memberikan gambaran berikut. Ekspor tersebut berisi 573.967 objek STIX 2.1 dan 986 laporan (*report*) yang terbit antara 5 Februari dan 30 Desember 2025. Dari 352 CVE yang disebut, 272 (77%) terhubung ke aktor, 330 (94%) ke *malware*, dan 328 (93%) ke teknik serangan. Data yang sama memuat 3.471 relasi sasaran (`targets`) ke lokasi dan 2.726 relasi sasaran ke 62 kelas sektor. Infrastruktur dan konfigurasi akuisisinya dijelaskan pada Subbab 4.2.2.

Namun, OpenCTI tidak menalar produk dan versi pada aset organisasi, sehingga konteks ancaman tersebut tidak dapat langsung dihubungkan ke pertanyaan "apakah aset saya terdampak". Riset yang benar-benar memakai OpenCTI juga masih jarang; contohnya S. Ruohonen et al. (2024) untuk atribusi serangan dan Chen et al. (2024) untuk kualitas *indicator of compromise* (IoC), keduanya tanpa representasi RDF atau ontologi.

Pilihan yang tampak paling sederhana adalah menggabungkan objek STIX dari OpenCTI ke SEPSES secara naif. Dalam *integrasi naif*, setiap objek STIX diubah menjadi *triple* tanpa memperhatikan kapan bukti terbit, kapan bukti berhenti berlaku, dan dari laporan mana bukti berasal. Analisis pendahuluan menunjukkan bahwa cara ini menimbulkan tiga jenis kesalahan yang terukur (Tabel 1.1).

1. **Kesalahan *coverage*.** Hanya 129 dari 352 CVE yang disebut CTI (36,6%) tersedia sebagai entitas pada salinan lokal SEPSES, sehingga sebagian besar konteks ancaman tidak tertaut ke kerentanan mana pun.
2. **Kesalahan waktu.** Misalkan analis mengambil keputusan pada *waktu keputusan* t = 30 September 2025. Bila waktu diabaikan, 45,8% asosiasi CVE–ancaman yang dipakai sebenarnya berasal dari laporan yang baru terbit sesudah t, sehingga informasi *bocor dari masa depan*. Pada t = 31 Desember 2025, 51,4% asosiasi sudah *usang*, yaitu bukti terbarunya lebih tua dari *jendela kebaruan* W = 90 hari.

3. **Kesalahan audit.** Ketika objek STIX dilebur menjadi *triple* datar, *provenance*-nya hilang. *Provenance* adalah catatan asal-usul yang menyatakan laporan, pembuat, dan waktu yang mendasari setiap pernyataan. Padahal kualitas dan ketepatan waktu CTI diketahui sangat bervariasi antarsumber (Li et al. 2019; Bouwman et al. 2020). Tinjauan sistematis KG untuk CTI juga mencatat *provenance* dan pembaruan pengetahuan sebagai persoalan terbuka (Bratsas et al. 2024).

Tabel 1.1. Indikator masalah dari analisis pendahuluan atas data OpenCTI, SEPSES, CVE List v5, dan KEV milik peneliti

Indikator	**Nilai**	**Makna bagi penelitian**
Konteks ancaman pada CVE di OpenCTI	aktor 77%, *malware* 94%, teknik 93% (dari 352 CVE)	Data CTI kaya akan konteks yang tidak dimiliki SEPSES
Konteks ancaman di SEPSES	tidak ada konsep aktor, kampanye, atau sektor	Perlu perluasan kosakata, bukan sekadar penambahan data
CVE CTI yang ada sebagai entitas di SEPSES lokal	129/352 (36,6%); berpotensi 271/352 (77,0%) dengan CVE List v5	Kesalahan *coverage*; perlu lapisan kerentanan yang kompatibel dengan SEPSES
Rekaman CVE List v5 dengan CPE eksplisit	7,71%	Kecocokan aset tidak selalu dapat dipastikan; status `UNKNOWN` harus dimodelkan
Asosiasi CVE–ancaman dari laporan yang terbit sesudah t = 30 Sep 2025	3.789/8.281 (45,8%)	Integrasi naif membocorkan bukti dari masa depan
Asosiasi yang usang (W = 90 hari) pada t = 31 Des 2025	4.256/8.281 (51,4%)	Integrasi naif memakai bukti yang tidak lagi relevan
Indicator kedaluwarsa per 17 Agu 2026	33.008/35.114 (94%); 18.906 dicabut (*revoked*)	Validitas waktu objek STIX harus ikut dinalar
Waktu laporan CTI pertama terhadap tanggal masuk KEV	175 dari 204 CVE KEV dilaporkan pada/sesudah `dateAdded`; median +379 hari	CTI ini bukan peringatan dini; nilainya ada pada konteks aktivitas terkini

Baris terakhir Tabel 1.1 sekaligus membatasi arah penelitian. Pada 175 dari 204 CVE yang tercantum di KEV, laporan CTI pertama baru terbit pada atau sesudah tanggal masuk KEV. Karena itu, data ini tidak cocok untuk memprediksi eksploitasi: label "masuk KEV sesudah t" hanya menghasilkan 0–8 kasus positif per jendela pengamatan. Nilai data ini terletak pada pertanyaan lain, yaitu kerentanan mana pada aset yang *masih* dipakai oleh ancaman yang relevan bagi organisasi pada waktu keputusan, beserta bukti yang mendukungnya.

Dari uraian tersebut, dibutuhkan integrasi CTI STIX 2.1 dari OpenCTI ke SE-

PSES *Knowledge Graph* yang memenuhi tiga sifat sekaligus, masing-masing menjawab satu jenis kesalahan di atas:

1. *benar*: CVE dan entitas ancaman ditautkan dengan tepat ke kerentanan dan aset (menjawab kesalahan *coverage*);
2. *dapat ditelusuri*: setiap pernyataan konteks ancaman membawa *provenance* (menjawab kesalahan audit);
3. *sesuai waktu keputusan*: hanya bukti yang *sah-waktu* (*admissible*) yang dipakai, yaitu bukti yang sudah terbit, belum dicabut atau kedaluwarsa, dan masih berada dalam jendela kebaruan pada waktu t (menjawab kesalahan waktu). Jawaban yang dihitung dengan aturan ini disebut jawaban *per waktu* t (*as-of* t).

Penelusuran literatur pendahuluan belum menemukan karya yang memetakan STIX 2.1 dari OpenCTI ke kosakata SEPSES dengan *provenance* dan validitas waktu yang dapat dikueri per waktu t untuk penilaian kerentanan per aset (Subbab 2.7). Penelitian ini diusulkan untuk mengisi celah tersebut dan mengevaluasinya secara kuantitatif melalui *competency question* (CQ) dan *gold standard*. CQ adalah pertanyaan yang harus dapat dijawab oleh KG, sedangkan *gold standard* adalah jawaban acuan yang dikurasi secara manual dari data mentah.

1.2 Rumusan Masalah

SEPSES *Knowledge Graph* mampu menghubungkan aset ke CVE beserta CVSS, CWE, dan CAPEC, tetapi tidak memuat konteks ancaman. OpenCTI memuat konteks ancaman dalam STIX 2.1, tetapi tidak menalar aset. Penggabungan naif keduanya menimbulkan tiga kesalahan teknis yang terukur (Tabel 1.1):

- kesalahan *coverage*: 36,6% CVE CTI tersedia di SEPSES lokal;
- kesalahan waktu: 45,8% asosiasi bocor dari masa depan dan 51,4% usang;
- kesalahan audit: *provenance* hilang.

Akibatnya, jawaban atas pertanyaan penilaian kerentanan berbasis ancaman pada aset organisasi menjadi tidak benar pada waktu keputusan dan tidak dapat diaudit. Masalah tersebut dirumuskan dalam satu pertanyaan penelitian (*research question*, RQ) berikut.

> **RQ.** Bagaimana CTI STIX 2.1 dari OpenCTI dapat diintegrasikan ke SEPSES *Knowledge Graph* sehingga pertanyaan penilaian kerentanan berbasis konteks ancaman pada aset organisasi dapat dijawab secara **benar**, **dapat ditelusuri sumbernya**, dan **sesuai waktu keputusan**?

RQ tersebut adalah satu pertanyaan dengan tiga kriteria keberhasilan, bukan tiga pertanyaan terpisah. Setiap kriteria diukur oleh satu ukuran evaluasi:

- kebenaran jawaban terhadap *gold standard* (U1);
- keabsahan waktu, yaitu tidak adanya bukti yang tidak sah-waktu dalam jawaban (U2);
- ketertelusuran, yaitu kelengkapan *provenance* (U3).

Rincian ukuran dan CQ disajikan pada Bab IV.

1.3 Batasan Masalah

Agar penelitian tetap terfokus dan dapat diselesaikan, ruang lingkupnya dibatasi sebagai berikut.

1. **Data CTI.** Data CTI yang digunakan hanya satu *snapshot* ekspor OpenCTI dari konektor AlienVault. Ekspor ini berisi 986 laporan terbitan Februari–Desember 2025, karena konektor dikonfigurasi untuk mulai mengimpor sejak 1 Januari 2025 (Subbab 4.2.2). Penambahan konektor atau sumber CTI lain hanya dilakukan bila diputuskan bersama pembimbing **[Diskusi: perlu sumber CTI tambahan atau cukup satu *feed*?]**.
2. **Data kerentanan.** Data kerentanan terdiri atas *seed* SEPSES, CVE List v5 untuk CVE 2025–2026 yang dikonversi ke kosakata SEPSES, dan katalog KEV per 27 Agustus 2026. EPSS hanya dipakai sebagai pembanding deskriptif pada studi kasus.
3. **Aset.** Aset yang dianalisis adalah profil aset *skenario* yang realistis, misalnya instansi pemerintah dan perguruan tinggi dengan produk yang lazim dipakai. Profil ini bukan inventaris aset (CMDB) organisasi nyata.
4. **Dimensi relevansi.** Data hanya memuat lima pasangan CVE–lokasi untuk Indonesia. Karena itu, relevansi ancaman terutama dinilai melalui sektor sasaran, dan wilayah dipakai bila datanya tersedia.
5. **Objek STIX yang dimodelkan.** Laporan, aktor (*intrusion set*), *malware*, teknik, kerentanan, sektor, negara, *indicator*, dan relasi di antaranya. *Indicator* dipakai untuk menjawab indikator mana yang masih berlaku bagi aktor atau *malware* yang terkait CVE (CQ3b). *Observable* (file, URL, domain) tidak dimodelkan, dan kualitas atau kedaluwarsa IOC tidak dievaluasi.
6. **Pembanding.** Pendekatan usulan dibandingkan dengan SEPSES saja dan dengan integrasi naif. CVSS, KEV, dan EPSS hanya dibandingkan secara deskriptif pada studi kasus.
7. **Aspek yang tidak dievaluasi.** Penelitian ini tidak mengevaluasi:
   - akurasi prediksi eksploitasi;
   - keunggulan peringkat (*ranking*) dibanding EPSS/KEV;
   - independensi atau ketergantungan antarsumber CTI;

- ekstraksi dari teks bebas (NER/LLM);
- *deployment* produksi;
- performa pada skala besar di luar data penelitian.

8. **Penalaran.** Penalaran bersifat deterministik dan berbasis aturan (SPARQL dan SHACL), tanpa model yang dilatih dari data.

1.4 Tujuan Penelitian

Untuk menjawab RQ pada Subbab 1.2, penelitian ini memiliki tiga tujuan. T1 dan T2 membangun integrasi yang memenuhi ketiga kriteria RQ, sedangkan T3 mengukur apakah kriteria tersebut tercapai.

T1. **Merancang** *application ontology*, yaitu ontologi yang dibuat untuk satu kebutuhan aplikasi tertentu. Ontologi ini memperluas kosakata SEPSES untuk konteks ancaman STIX 2.1: laporan, sektor dan wilayah sasaran, *provenance* berbasis PROV-O (Lebo et al. 2013), dan atribut validitas waktu. Ontologi diturunkan dari CQ dan divalidasi dengan SHACL (Knublauch and Kontokostas 2017). Tujuan ini terutama melayani kriteria *dapat ditelusuri*. Pola representasi *provenance* per laporan masih dipilih **[Diskusi: RDF-star seperti ICS-SEC KG atau *named graph* per laporan?]**.

T2. **Membangun** alur integrasi OpenCTI ke SEPSES. Alur ini mencakup pemetaan STIX ke RDF, *entity linking* (penautan objek STIX ke entitas SEPSES yang sama), pemisahan graf per sumber, dan penalaran *admissibility* per waktu t. Tujuan ini melayani kriteria *benar* dan *sesuai waktu keputusan*. Targetnya adalah F1 makro $\geq 0{,}90$ untuk jawaban CQ pada *test set gold standard* dan 0 jawaban yang memakai bukti tidak sah-waktu **[Diskusi: ambang F1 $\geq 0{,}90$ dan 0 bukti tidak sah-waktu adalah usulan; dibekukan bersama pembimbing sebelum *test set* dibuka]**.

T3. **Mengevaluasi** dampak integrasi tersebut terhadap penilaian kerentanan berbasis aset. Pembandingnya adalah SEPSES saja dan integrasi naif. Evaluasi dilengkapi studi kasus *tier* prioritas (kelas prioritas) bergaya tabel keputusan SSVC (Spring et al. 2019) yang transparan dan seluruhnya dapat ditelusuri ke bukti **[Diskusi: target 100% ketertelusuran adalah usulan; jendela kebaruan utama W = 180 hari dengan analisis sensitivitas W = 90 hari]**.

1.5 Manfaat Penelitian

1.5.1 Manfaat Akademik

1. Memberikan perluasan kosakata SEPSES dari data referensi ATT&CK yang statis menjadi CTI operasional yang bertanggal. Perluasan ini mencakup korban

sektor/negara, *provenance* per laporan, validitas waktu, dan *shape* SHACL, serta melanjutkan garis kerja SEPSES dan ICS-SEC KG (Kiesling et al. 2019; Kurniawan, Kiesling, Winkler, et al. 2024).

2. Memberikan metode integrasi yang sadar waktu, yaitu aturan *admissibility* per waktu t yang dapat diterapkan pada KG keamanan lain yang menggabungkan CTI bertanggal.

3. Memberikan bukti empiris tentang besarnya kesalahan waktu dan *provenance* pada integrasi naif, diukur dengan protokol evaluasi berbasis CQ dan *gold standard*. Protokol ini melengkapi evaluasi KG keamanan sebelumnya yang umumnya berupa demonstrasi *use case*. *Gold standard* tersebut juga berpotensi dipakai ulang sebagai tolok ukur tanya-jawab bagi pendekatan KG-RAG (Kurniawan, Kiesling, and Ekelhart 2024) pada penelitian lanjutan.

1.5.2 Manfaat Praktis

1. Analis keamanan memperoleh konteks ancaman per pasangan aset–CVE (aktor, teknik, sektor sasaran, status KEV) yang dihitung per waktu keputusan dan dapat diaudit hingga ke laporan sumbernya.

2. *Tier* prioritas yang dihasilkan bersifat transparan karena setiap keputusan dapat dijelaskan melalui jalur bukti. *Tier* ini melengkapi, bukan menggantikan, CVSS, EPSS, dan KEV.

3. Artefak penelitian (ontologi, aturan pemetaan, templat kueri, dan data uji) dapat digunakan kembali oleh pengelola ekosistem SEPSES maupun organisasi yang memakai OpenCTI.

Manfaat tersebut dibatasi oleh ruang lingkup pada Subbab 1.3. Penelitian ini tidak mengklaim peringkat yang lebih akurat daripada EPSS/KEV, tidak memprediksi eksploitasi, dan diuji pada aset skenario serta satu sumber CTI.

1.6 Definisi Operasional Istilah

Tabel 1.2 merangkum istilah kunci yang dipakai secara konsisten di seluruh proposal.

Tabel 1.2. Definisi operasional istilah kunci

Istilah	**Arti dalam penelitian ini**
Asosiasi CVE–ancaman	Relasi STIX yang menghubungkan CVE dengan aktor, *malware*, atau teknik serangan

Istilah	Arti dalam penelitian ini
Waktu keputusan t	Saat analis mengambil keputusan; semua jawaban dihitung per waktu t (*as-of* t)
Jendela kebaruan W	Batas umur bukti terbaru agar asosiasi dianggap masih relevan; utama 180 hari, sensitivitas 90 hari
Bukti sah-waktu (*admissible*)	Bukti yang sudah terbit, belum dicabut atau kedaluwarsa, dan masih berada dalam W pada waktu t
Bocor dari masa depan	Bukti yang baru terbit sesudah t tetapi ikut dipakai dalam jawaban
Usang	Bukti yang tetap dipakai meskipun bukti terbarunya lebih tua dari W
Provenance	Catatan asal-usul suatu pernyataan: laporan, pembuat, waktu, dan referensi
Integrasi naif	Penggabungan STIX ke RDF tanpa penalaran waktu dan *provenance*; dipakai sebagai pembanding
Exposure	Status keterpaparan aset terhadap CVE: TRUE, FALSE, atau UNKNOWN
Competency question (CQ)	Pertanyaan yang harus dapat dijawab KG; dasar perancangan dan evaluasi
Gold standard	Jawaban acuan untuk setiap CQ yang dikurasi manual dari data mentah
Tier prioritas	Kelas prioritas keluaran tabel keputusan bergaya SSVC
Konektor (*connector*)	Modul OpenCTI yang mengimpor atau mengekspor data

1.7 Sistematika Penulisan

Proposal ini disusun dalam empat bab.

Bab I Pendahuluan menguraikan latar belakang, rumusan masalah, batasan masalah, tujuan, manfaat, dan definisi operasional istilah.

Bab II Tinjauan Pustaka menyintesis literatur tentang KG dan ontologi keamanan siber, integrasi CTI/STIX, kualitas dan waktu CTI, serta prioritisasi kerentanan, lalu memetakan posisi penelitian ini terhadap karya-karya terdekat.

Bab III Landasan Teori menjelaskan teori yang dipakai langsung oleh metode, antara lain RDF dan *named graph*, rekayasa ontologi, kosakata SEPSES, STIX 2.1 dan OpenCTI, PROV-O, *admissibility* waktu, SHACL, pencocokan aset melalui CPE, tabel keputusan SSVC, dan metrik evaluasi.

Bab IV Metode dan Rancangan Penelitian memaparkan pendekatan penelitian, kebutuhan data dan perangkat, bagan alir, rancangan ontologi dan integrasi, rancangan penalaran, desain eksperimen dan evaluasi, hasil pendahuluan, ancaman validitas, serta jadwal penelitian.

BAB II
TINJAUAN PUSTAKA

Bab ini memetakan penelitian terdahulu yang relevan dengan integrasi *cyber threat intelligence* (CTI) ke dalam *knowledge graph* (KG) kerentanan untuk penilaian kerentanan berbasis aset. Pembahasan disusun per kelompok pendekatan, bukan per paper. Setiap kelompok dibahas menurut tren, kekuatan, dan keterbatasannya (Subbab 2.2 sampai 2.5). Hasilnya dirangkum dalam matriks perbandingan (Subbab 2.6), lalu dirumuskan menjadi *gap* penelitian (Subbab 2.7). Bab ini ditutup dengan posisi penelitian terhadap karya-karya terdekat (Subbab 2.8).

2.1 Metode Tinjauan

Tinjauan disusun sebagai *systematic literature review* (SLR) mengikuti pedoman Kitchenham and Charters (2007). Alur seleksinya dilaporkan mengikuti PRISMA 2020 (Page et al. 2021). Empat pertanyaan tinjauan dirumuskan, dan Tabel 2.1 menunjukkan subbab yang menjawab masing-masing.

Tabel 2.1. Pertanyaan tinjauan dan subbab yang menjawabnya

Kode	Pertanyaan tinjauan	Dijawab pada
SLR-RQ1	Bagaimana CTI terstruktur (STIX/OpenCTI/MISP) diintegrasikan dengan pengetahuan kerentanan dalam KG atau ontologi, dan bagaimana integrasi itu dievaluasi?	Subbab 2.2 dan 2.3
SLR-RQ2	Metode apa yang memprioritaskan kerentanan dengan konteks ancaman dan/atau aset, dan bagaimana metode itu dievaluasi?	Subbab 2.5
SLR-RQ3	Bagaimana kualitas CTI, yaitu *provenance*, kepercayaan sumber, ketepatan waktu, dan duplikasi, diperlakukan saat CTI dipakai untuk keputusan?	Subbab 2.4
SLR-RQ4	Kombinasi apa dari ketiga hal tersebut yang belum diteliti?	Subbab 2.6 sampai 2.8

Tabel 2.2 merangkum status sumber literatur saat draft ini disusun. Pencarian awal memakai korpus lokal dan basis data terbuka (OpenAlex, Crossref, arXiv), dan setiap entri baru diverifikasi melalui DOI atau halaman penerbit. Pencarian formal di Scopus dan SpringerLink dengan *string* pencarian yang sudah disiapkan belum dijalankan. Karena itu, angka PRISMA final akan menyusul dan sintesis dalam bab ini masih bersifat sementara.

Tabel 2.2. Status sumber literatur pada draft ini

Sumber	Rekaman	Keterangan
Korpus lokal	53	Dibaca penuh; 34 masuk, 19 dikeluarkan karena di luar domain
Kandidat baru (API terbuka)	154	Terverifikasi DOI/penerbit; 16 berstatus *preprint*
Tambahan dari mahasiswa	2	ICS-SEC KG dan Debapt (teks lengkap)
Forward citation SEPSES	96	Karya yang mengutip Kiesling et al. (2019) (OpenAlex)
Rekaman unik setelah deduplikasi	186	*Screening* formal judul dan abstrak belum dilakukan
Scopus dan SpringerLink	–	*String* pencarian siap; dijalankan dengan akses institusi

2.2 *Knowledge Graph* Keamanan Siber dan Kerentanan

Tren. Survei-survei terkini menunjukkan bahwa riset KG keamanan siber tumbuh pesat, tetapi implementasi KG yang besar, terbuka, dan terus diperbarui masih terbatas (Sikos 2023; Zhao, Jiang, et al. 2024). Sebagian besar KG dirancang untuk ruang lingkup sempit, seperti aktor ancaman, analisis log, kerentanan, atau CTI, dan hanya mendukung satu skenario aplikasi.

Dalam kelompok ini, SEPSES KG (Kiesling et al. 2019) merupakan salah satu sumber daya terbuka yang paling mapan. SEPSES mengintegrasikan CVE, CVSS, CPE, CWE, dan CAPEC dalam kosakata RDF yang strukturnya menyerupai sumber aslinya. KG ini diperbarui melalui alur *extract–transform–load* (ETL) dengan validasi SHACL. SEPSES juga mendemonstrasikan penilaian kerentanan berbasis aset: perangkat lunak yang terpasang pada sebuah *host* ditautkan ke CPE, lalu ke CVE yang memengaruhinya melalui properti `cve:hasCPE`. Kelompok peneliti yang sama kemudian memperluas fondasi ini:

- ATT&CK-KG menautkan serangan ke taktik dan teknik penyerang (Kurniawan, Ekelhart, and Kiesling 2021);
- KRYSTAL dan VloGraph memakai KG untuk deteksi serangan dan analisis log (Kurniawan, Ekelhart, Kiesling, Quirchmayr, et al. 2022; Kurniawan, Ekelhart, Kiesling, Winkler, et al. 2022);
- ICS-SEC KG memperluas SEPSES ke domain sistem kendali industri (Kurniawan, Kiesling, Winkler, et al. 2024).

Di luar grup ini, BRON (Hemberg et al. 2024) menautkan ATT&CK, CAPEC, CWE, CVE, dan CPE untuk analitik ancaman.

Ekosistem SEPSES juga dikembangkan melalui proyek kelompok pada mata kuliah *Software Engineering* yang diampu pembimbing. Proyek-proyek ini berupa repositori kode, bukan publikasi, tetapi relevan sebagai karya terkait terdekat. Isinya mencakup tiga arah:

- reproduksi alur SEPSES dalam *pipeline* agentik;
- KG keamanan dari teks tak terstruktur, termasuk ekstraksi entitas bergaya STIX (laporan, *malware*, kerentanan) yang ditautkan ke CVE SEPSES;
- sistem tanya-jawab berbasis KG dan LLM di atas SEPSES.

Proyek-proyek tersebut dirancang untuk digabungkan ke satu repositori yang memuat data terstruktur dan tak terstruktur. Penelitian ini melengkapinya dari sisi data *terstruktur*, yaitu CTI STIX dari OpenCTI. Fokusnya adalah penalaran keabsahan waktu per waktu keputusan dan *provenance* per laporan sebagai dasar evaluasi, sesuatu yang bukan fokus utama proyek-proyek tersebut.

Kekuatan. Kelompok ini menghasilkan integrasi lintas standar yang stabil. Pengenalnya sudah baku (ID CVE, CWE, dan CAPEC), sehingga penautan entitas (*entity linking*) antarsumber relatif lugas.

Keterbatasan. Keterbatasannya ada pada jenis pengetahuan yang diintegrasikan. Sumber yang dipakai adalah pengetahuan *referensi*, yaitu daftar kerentanan, kelemahan, pola serangan, dan katalog teknik, bukan laporan aktivitas ancaman yang bertanggal. ICS-SEC KG menggambarkan hal ini dengan jelas. Data MITRE ATT&CK yang didistribusikan sebagai bundel STIX dipetakan ke kosakata `attack:` melalui aturan pemetaan RML (*RDF Mapping Language*) (SEPSES Team 2024). Namun, pemetaan tersebut hanya mengambil atribut referensi seperti nama, deskripsi, relasi, dan rujukan eksternal. Atribut yang menjadi ciri CTI operasional tidak ikut dipetakan:

- laporan dan isinya (`object_refs`);
- waktu terbit (`published`);
- masa berlaku (`valid_from`/`valid_until`) dan pencabutan (`revoked`);
- pembuat (`created_by_ref`);
- korban berupa sektor dan negara.

Evaluasi SEPSES dan ICS-SEC KG juga berupa demonstrasi *use case*, bukan pengukuran kuantitatif terhadap jawaban yang benar.

2.3 Ontologi dan *Knowledge Graph* CTI

Tren. Kelompok kedua merepresentasikan CTI itu sendiri. Ada tiga arah penelitian.

1. **Ontologisasi standar CTI.** STIX 2.1 (Jordan et al. 2021) menjadi model pertukaran

CTI yang dominan, dan beberapa penelitian menurunkan ontologi darinya. Liu et al. (2020) menyusun pemodelan ontologi KG keamanan jaringan berbasis STIX. Mavroeidis et al. (2021) membangun ontologi OWL untuk tipologi aktor ancaman yang memperluas semantik STIX 2.1.

2. **KG CTI dari teks bebas.** Arah yang paling banyak diteliti adalah ekstraksi entitas dan relasi dari laporan CTI berbentuk teks. Contohnya Open-CyKG (Sarhan and Spruit 2021), CSKG4APT (Ren et al. 2023), dan yang terbaru Debapt (Zhao, Qi, et al. 2026). Debapt memakai ontologi profil penyerang (VICTOR) dan debat multi-agen berbasis *large language model* (LLM) untuk mengekstrak profil kelompok *advanced persistent threat* (APT). Debapt juga mengagregasikan fakta lintas laporan dengan skor keyakinan sederhana: fakta yang dikonfirmasi beberapa laporan diberi skor lebih tinggi, tanpa memeriksa apakah laporan-laporan itu saling bergantung dan tanpa penalaran waktu.
3. **OpenCTI dalam riset.** Meskipun OpenCTI banyak dipakai praktisi, penelitian *peer-reviewed* yang memakainya masih sedikit. S. Ruohonen et al. (2024) menambahkan kapabilitas atribusi serangan ke OpenCTI, sedangkan Chen et al. (2024) memakai graf STIX di atas OpenCTI untuk meningkatkan kualitas *indicator of compromise* (IoC). Dalam konteks Indonesia, Briliyant et al. (2021) membahas otomasi diseminasi CTI dengan STIX.

Kekuatan. Ontologisasi STIX memberi dasar konseptual yang selaras dengan standar pertukaran CTI. KG dari teks menjangkau informasi yang tidak tersedia dalam bentuk terstruktur. Studi berbasis OpenCTI menunjukkan bahwa data operasional dari platform tersebut dapat dipakai untuk penelitian.

Keterbatasan. Ontologi STIX yang ada berfokus pada *konsep*; data instans, keterkaitan dengan aset organisasi, dan dimensi waktu tidak menjadi fokus. KG dari teks bergantung pada kualitas ekstraksi dan berhenti pada pembangunan graf atau profil, bukan pada pemakaian graf untuk keputusan atas aset. Studi berbasis OpenCTI tidak merepresentasikan data sebagai RDF/ontologi dan tidak menautkannya ke kosakata kerentanan seperti SEPSES. SLR Bratsas et al. (2024) tentang KG dan *semantic web* dalam CTI juga menyebut *provenance* dan pembaruan KG secara otomatis sebagai masalah terbuka.

2.4 Kualitas, *Provenance*, dan Waktu CTI

Tren. Kelompok ketiga mengukur kualitas CTI. Sebagian besar studi menilai *feed*, yaitu aliran data CTI dari satu penyedia:

- Li et al. (2019) membandingkan banyak *feed* berdasarkan volume, keunikan, ketepatan

waktu, dan akurasi;

- Griffioen et al. (2020) dan Bouwman et al. (2020) menilai kualitas *feed* terbuka dan komersial, termasuk keterlambatannya;
- Schlette et al. (2020) dan Zibak et al. (2022) merumuskan dimensi kualitas CTI, termasuk ketepatan waktu dan kelengkapan;
- Allegretta et al. (2023) menilai kesiapan dataset CTI *crowd-sourced*, termasuk AlienVault Open Threat Exchange (OTX), untuk mendukung analisis;
- survei Tounsi and Rais (2018) menegaskan bahwa CTI teknis cepat kehilangan nilai.

Sebagian penelitian menyentuh *provenance* dan ketergantungan sumber. FeedRank (Meier et al. 2018) meranking *feed* dengan memperhitungkan pemakaian ulang entri antar-*feed*. TRACE-CTI (Valletta et al. 2026), yang masih berstatus *preprint*, mengatur tata kelola klaim taktik, teknik, dan prosedur (TTP) hasil ekstraksi dalam KG yang dapat diaudit. Dalam literatur integrasi data, ketergantungan sumber telah lama dimodelkan (Dong et al. 2009), tetapi penerapannya pada klaim CTI belum ditemukan.

Kekuatan. Kelompok ini memiliki kerangka pengukuran kualitas yang matang dan menunjukkan bahwa ketepatan waktu serta asal sumber sangat menentukan nilai CTI.

Keterbatasan. Pertama, pengukuran kebanyakan dilakukan pada IoC jaringan (IP, domain, *hash*), bukan pada klaim yang menghubungkan CVE dengan aktivitas ancaman. Kedua, hasilnya dilaporkan sebagai karakteristik *feed*, belum diwujudkan sebagai aturan yang dijalankan saat KG menjawab pertanyaan. Contoh aturan semacam itu adalah hanya memakai bukti yang sah-waktu pada waktu keputusan.

2.5 Prioritisasi Kerentanan Berbasis Konteks

Tren. Kelompok keempat membahas penentuan kerentanan mana yang ditangani lebih dahulu. Sinyal publik yang paling banyak dipakai adalah:

- CVSS (Forum of Incident Response and Security Teams 2019), yang mengukur keparahan teknis tetapi tidak mencerminkan konteks organisasi, dan skornya dapat terlambat terbit (J. Ruohonen 2019);
- EPSS, yang memperkirakan peluang eksploitasi global dari banyak sinyal (Jacobs, Romanosky, Edwards, et al. 2021; Jacobs, Romanosky, Suciu, et al. 2023);
- katalog KEV (Cybersecurity and Infrastructure Security Agency 2026), yang menyatakan bahwa sebuah kerentanan pernah dieksploitasi dan menjadi dasar kewajiban remediasi BOD 22-01 (Cybersecurity and Infrastructure Security Agency 2021);

- SSVC (Spring et al. 2019), yang mengusulkan tabel keputusan yang bergantung pada pemangku kepentingan.

Studi empiris terbaru menunjukkan bahwa sistem skor publik ini sering tidak konsisten (Koscinski et al. 2025). Kombinasi KEV/EPSS lalu CVSS juga sudah dievaluasi dalam skala besar oleh Shimizu and Hashimoto (2026).

Penelitian lain menambahkan konteks aset dan ancaman:

- CAVP (Jung et al. 2022) dan kerangka metrik Albanese et al. (2023) menambahkan konteks lingkungan pada penilaian kerentanan;
- ILLATION (Zeng et al. 2024) belajar dari konteks jaringan;
- FRAPE (Parente et al. 2025) menggabungkan konteks aset, informasi ancaman tingkat CVE, dan penjelasan;
- Scott and Cohen (2025) memadukan konteks titik akhir dengan EPSS dan KEV;
- Samtani et al. (2022) menautkan eksploit dari *dark web* ke kerentanan pada aset hasil pemindaian;
- McCoy et al. (2024) (*preprint*) membangun KG dan memakai kriteria ATT&CK untuk meranking CVE per organisasi, dengan evaluasi memakai metrik peringkat nDCG.

Kekuatan. Kelompok ini paling dekat dengan keputusan operasional dan sudah dievaluasi pada skala yang besar.

Keterbatasan. Konteks ancaman yang dipakai umumnya berupa sinyal tingkat CVE (EPSS, KEV, eksploit publik) atau kriteria ATT&CK yang statis. Aktivitas ancaman teramati yang terstruktur dan bertanggal, yaitu siapa yang memakai CVE, terhadap sektor dan negara mana, serta kapan, belum dimanfaatkan. Evaluasi utilitas juga terhambat oleh label: prioritas yang "benar" bagi sebuah organisasi sulit diperoleh, dan prediksi eksploitasi menuntut kehati-hatian terhadap kebocoran waktu (Arp et al. 2022).

2.6 Matriks Perbandingan

Tabel 2.3 merangkum karya-karya dari keempat kelompok menurut dimensi yang menjadi fokus penelitian ini. Penilaian "sebagian" berarti aspek tersebut disentuh, tetapi tidak dimodelkan atau dievaluasi secara eksplisit.

Tabel tersebut memperlihatkan pola yang jelas. Karya yang menautkan *aset* (SEPSES, ICS-SEC KG, FRAPE, McCoy) tidak memakai CTI bertanggal maupun validitas waktu. Sebaliknya, karya yang memakai CTI bertanggal (studi OpenCTI dan kualitas *feed*) tidak menautkannya ke aset. Belum ada karya yang mengisi keempat dimensi se-

Tabel 2.3. Perbandingan karya menurut dimensi penelitian

Karya	**Sumber data**	**CTI bertanggal**	***Provenance***	**Validitas waktu**	**Aset**	**Evaluasi**
SEPSES (Kiesling et al. 2019)	CVE, CVSS, CPE, CWE, CAPEC	tidak	sebagian	tidak	ya	*use case*
ICS-SEC KG (Kurniawan, Kiesling, Winkler, et al. 2024)	ATT&CK (STIX), ICS *advisory*, NVD, CWE, CAPEC	tidak	sebagian	tidak	ya	*use case*
BRON (Hemberg et al. 2024)	ATT&CK, CAPEC, CWE, CVE, CPE	tidak	tidak	tidak	tidak	analitik
Ontologi STIX (Liu et al. 2020; Mavroeidis et al. 2021)	Model STIX	tidak	tidak	tidak	tidak	contoh
Open-CyKG, CSKG4APT (Sarhan and Spruit 2021; Ren et al. 2023)	Teks laporan	sebagian	tidak	tidak	tidak	ekstraksi
Debapt (Zhao, Qi, et al. 2026)	Teks laporan	sebagian	sebagian	sebagian	tidak	ekstraksi (F1)
TRACE-CTI (Valletta et al. 2026)	Klaim TTP hasil ekstraksi	sebagian	ya	sebagian	tidak	*preprint*
Chen et al. (2024)	OpenCTI (AlienVault, CVE, KEV)	ya	sebagian	sebagian	tidak	kualitas IoC
S. Ruohonen et al. (2024)	OpenCTI	ya	tidak	tidak	tidak	atribusi
Kualitas *feed* (Li et al. 2019; Griffioen et al. 2020)	*Feed* IoC	ya	sebagian	ya	tidak	pengukuran
Shimizu and Hashimoto (2026)	KEV, EPSS, CVSS	tidak	tidak	sebagian	tidak	skala besar
FRAPE (Parente et al. 2025)	Aset, CVE, informasi ancaman	tidak	tidak	tidak	ya	studi kasus
McCoy et al. (2024)	KG + ATT&CK	tidak	tidak	tidak	ya	nDCG
Penelitian ini	OpenCTI (STIX 2.1) + SEPSES + CVE List v5 + KEV	ya	ya	ya	ya	CQ + *gold standard*

kaligus.

2.7 *Gap* Penelitian

Sintesis keempat kelompok di atas menghasilkan tiga pengamatan.

1. KG kerentanan yang mapan, seperti SEPSES dan ICS-SEC KG, memuat pengetahuan referensi tetapi tidak memuat aktivitas ancaman teramati yang bertanggal. Dalam ICS-SEC KG, STIX sudah dipetakan, tetapi hanya untuk data ATT&CK yang statis (Subbab 2.2).
2. KG CTI yang memuat aktivitas ancaman umumnya dibangun dari teks dan berhenti pada graf atau profil, tanpa menautkan ke produk/versi aset dan tanpa menalar validitas waktu. OpenCTI, sebagai sumber CTI terstruktur, hampir tidak dipakai dalam riset semantik (Subbab 2.3).
3. Penelitian kualitas CTI menunjukkan bahwa ketepatan waktu dan asal sumber sangat menentukan nilai CTI, tetapi temuan ini belum diwujudkan sebagai aturan

yang dijalankan KG saat menjawab pertanyaan pada waktu keputusan tertentu (Subbab 2.4).

Dari pengamatan tersebut, *gap* penelitian dirumuskan sebagai berikut.

> **Gap.** Belum ditemukan penelitian yang mengintegrasikan CTI terstruktur dari OpenCTI (STIX 2.1) ke KG kerentanan berbasis SEPSES dengan *provenance* per laporan dan validitas waktu yang dapat dikueri per waktu keputusan, serta mengevaluasi secara kuantitatif kebenaran jawaban penilaian kerentanan berbasis aset yang dihasilkannya.

Pernyataan "belum ditemukan" dibatasi pada korpus dan pencarian yang telah dilakukan, dan akan diuji ulang setelah pencarian Scopus dan SpringerLink selesai.

Gap ini menjadi dasar RQ pada Subbab 1.2. Ketiga kriteria dalam RQ, yaitu benar, dapat ditelusuri, dan sesuai waktu keputusan, masing-masing menjawab satu bagian *gap*: penautan ke kosakata SEPSES, *provenance* per laporan, dan validitas waktu. Teori yang dibutuhkan untuk ketiganya dibahas pada Bab III.

2.8 Posisi Penelitian terhadap Karya Terdekat

Tabel 2.3 membandingkan karya menurut dimensi. Tabel 2.4 melengkapinya dengan merinci, untuk setiap karya terdekat, hal yang belum dilakukan dibanding penelitian ini. Daftar ini berasal dari penelusuran pendahuluan dan masih dapat berubah setelah *screening* formal.

Dari Tabel 2.4 terlihat bahwa unsur-unsur penelitian ini telah muncul secara terpisah dalam empat kelompok karya:

- KG kerentanan (SEPSES, ICS-SEC KG);
- CTI berbasis OpenCTI (Chen et al. 2024);
- prioritisasi berbasis konteks ancaman (McCoy et al. 2024; Shimizu and Hashimoto 2026);
- *provenance* klaim CTI (Valletta et al. 2026).

Keaslian penelitian ini terletak pada penggabungan keempatnya secara terkontrol: CTI STIX terstruktur ditautkan ke kosakata SEPSES, dinalar per waktu keputusan, dan dapat ditelusuri ke laporan sumbernya. Penelitian ini juga mengukur secara kuantitatif dampak kesalahan waktu pada integrasi naif.

Secara ringkas, posisi penelitian ini adalah sebagai berikut.

- **Terhadap SEPSES dan ICS-SEC KG**, penelitian ini adalah perluasan langsung: memakai pola dan kosakata yang sama, tetapi untuk CTI operasional yang bertanggal.

Tabel 2.4. Karya terdekat dan pembedanya dengan penelitian ini

Karya	**Fokus**	**Yang belum dilakukan dibanding penelitian ini**
Kiesling et al. (2019) (SEPSES)	KG keamanan terintegrasi (CVE, CVSS, CPE, CWE, CAPEC) dengan ETL berbasis RML dan SHACL; demonstrasi penilaian kerentanan aset melalui CPE.	Tidak memuat konteks ancaman (aktor, sektor, kampanye), tidak menalar waktu bukti, dan tidak dievaluasi secara kuantitatif dengan *competency question*.
Kurniawan, Kiesling, Winkler, et al. (2024) (ICS-SEC KG)	Perluasan SEPSES ke domain sistem kendali industri; ATT&CK dipetakan dari STIX; *provenance* relasi memakai RDF-star; evaluasi berupa dua *use case* demonstratif.	ATT&CK hanya sebagai data referensi statis: tanpa laporan, waktu terbit, pembuat, validitas/pencabutan, korban sektor/negara, penalaran per waktu t, maupun evaluasi kuantitatif.
Chen et al. (2024)	Peningkatan kualitas IoC dengan graf STIX di atas OpenCTI (termasuk konektor AlienVault dan KEV); skor *severity* dan *confidence*.	Berfokus pada IoC, bukan kerentanan dan aset; tanpa RDF/ontologi; evaluasi berupa studi kasus tanpa *ground truth*.
McCoy et al. (2024) (*preprint*)	KG dari data kerentanan dan ancaman publik; kriteria penyerang dari ATT&CK untuk meranking CVE per organisasi (nDCG).	Tidak memakai CTI STIX operasional dari OpenCTI; tidak menyimpan *provenance* per laporan dan validitas waktu; berfokus pada peringkat, bukan integrasi yang dapat diaudit.
Shimizu and Hashimoto (2026)	Pohon keputusan dua tahap (KEV/EPSS lalu CVSS) yang diuji pada 28.377 CVE.	Tanpa konteks aktor/sektor, tanpa KG aset, dan tanpa jejak bukti per keputusan.
Zhao, Qi, et al. (2026) (Debapt)	Ekstraksi profil penyerang dari teks bebas memakai ontologi VICTOR dan debat multi-agen LLM; *gold standard* dengan anotasi terverifikasi.	Bersumber dari teks tidak terstruktur; tidak ditautkan ke KG kerentanan/aset; agregasi lintas laporan tanpa penalaran waktu.
Valletta et al. (2026) (TRACE-CTI, *preprint*)	Tata kelola klaim TTP hasil ekstraksi dalam KG: *provenance*, *trust*, *versioning*, dan koroborasi.	Menangani klaim TTP, bukan klaim kerentanan; tidak ditautkan ke SEPSES dan aset; tidak memakai kosakata *provenance* standar PROV-O.
Penelitian ini	Integrasi CTI STIX 2.1 OpenCTI ke SEPSES dengan *provenance* per laporan dan validitas waktu untuk penilaian kerentanan per aset.	Dievaluasi secara kuantitatif (kebenaran, keabsahan waktu, ketertelusuran) terhadap SEPSES saja dan integrasi naif.

- **Terhadap KG CTI dari teks**, penelitian ini bersifat pelengkap: hasil ekstraksi teks dapat menjadi sumber tambahan di masa depan.

- **Terhadap penelitian prioritisasi**, penelitian ini tidak bersaing dalam akurasi peringkat, tetapi menyediakan konteks ancaman yang benar dan dapat diaudit sebagai dasar tabel keputusan.
- **Terhadap penelitian kualitas CTI**, penelitian ini mengoperasionalkan aspek waktu dan asal sumber sebagai aturan penalaran.

[Diskusi: Apakah posisi penelitian sebagai perluasan langsung SEPSES/ICS-SEC untuk CTI operasional sudah tepat, atau perlu ditekankan sebagai modul resmi SEPSES?]

BAB III
LANDASAN TEORI

Bab ini memuat teori yang dipakai langsung oleh metode penelitian pada Bab IV. Pemilihannya selektif, dan setiap kelompok subbab menjawab satu kebutuhan rancangan:

- bagaimana data direpresentasikan dan ditautkan (Subbab 3.1–3.4);
- bagaimana asal-usul dan waktu sebuah pernyataan dicatat dan ditalar (Subbab 3.5–3.6);
- bagaimana kualitas struktur data dijaga (Subbab 3.7);
- bagaimana kerentanan dikaitkan dengan aset dan diprioritaskan (Subbab 3.8–3.9);
- bagaimana hasilnya diukur (Subbab 3.10).

Subbab 3.11 merangkum hubungan setiap teori dengan tahap metode dan ukuran keberhasilan U1–U5.

Benang merahnya adalah satu pertanyaan penelitian: bagaimana CTI STIX 2.1 dari OpenCTI diintegrasikan ke SEPSES *Knowledge Graph* sehingga pertanyaan penilaian kerentanan berbasis konteks ancaman dapat dijawab secara benar, dapat ditelusuri sumbernya, dan sesuai waktu keputusan. Setiap sifat membutuhkan landasan formal:

- sifat *benar* dibangun oleh representasi dan penautan entitas (Subbab 3.1–3.4);
- sifat *dapat ditelusuri* dibangun oleh *provenance* (Subbab 3.5);
- sifat *sesuai waktu keputusan* dibangun oleh keabsahan waktu bukti (Subbab 3.6).

Ketercapaian ketiganya diukur dengan teori evaluasi pada Subbab 3.10.

3.1 *Knowledge Graph*, RDF, dan *Named Graph*

Knowledge graph (KG) dalam penelitian ini dipahami secara operasional sebagai himpunan pernyataan tentang entitas dan relasinya yang direpresentasikan dengan model data RDF dan diberi makna oleh sebuah ontologi. Definisi ini sengaja sempit: yang dibutuhkan metode bukan konsep KG secara umum, tetapi sifat formal RDF yang menentukan bagaimana pernyataan CTI dapat digabungkan, dipisahkan per sumber, dan dikueri.

3.1.1 Model data RDF

RDF 1.1 (Cyganiak et al. 2014) menyatakan pengetahuan sebagai *triple* (s, p, o), yaitu subjek–predikat–objek. Contohnya, pernyataan "aktor X menargetkan CVE Y" adalah satu *triple* dengan X sebagai subjek, "menargetkan" sebagai predikat, dan Y sebagai objek. Misalkan I himpunan IRI, B himpunan *blank node*, dan L himpunan literal.

Sebuah *triple* RDF adalah

$$(s, p, o) \in (I \cup B) \times I \times (I \cup B \cup L), \tag{3-1}$$

dan sebuah *RDF graph* G adalah himpunan *triple*. Dua sifat penting bagi integrasi mengikuti dari definisi ini. Pertama, penggabungan dua graf adalah operasi gabungan himpunan, sehingga data OpenCTI dan SEPSES dapat disatukan tanpa skema tabel bersama asalkan memakai IRI yang sama untuk entitas yang sama. Karena itu, *entity linking* (tahap 5) pada dasarnya adalah pemilihan IRI yang konsisten, misalnya IRI CVE SEPSES untuk objek `vulnerability` STIX. Kedua, sebuah *triple* tidak membawa informasi tentang siapa yang menyatakannya atau kapan. Bila objek STIX dilebur menjadi *triple* datar dalam satu graf, jejak laporan, pembuat, dan waktu hilang. Inilah sumber masalah audit yang dirumuskan pada Bab I, dan inilah yang dimodelkan oleh skenario pembanding B1 (integrasi naif).

3.1.2 RDF *dataset* dan *named graph*

RDF 1.1 juga mendefinisikan *RDF dataset*

$$D = \{\, G_0,\ (n_1, G_1),\ \ldots,\ (n_k, G_k) \,\}, \tag{3-2}$$

dengan G_0 sebagai *default graph* dan setiap pasangan (n_i, G_i) sebagai *named graph* yang diberi nama IRI n_i (Cyganiak et al. 2014). Karena n_i adalah IRI, nama graf itu sendiri dapat menjadi subjek *triple* lain, misalnya pernyataan bahwa graf n_i dihasilkan dari laporan tertentu pada waktu tertentu. Dataset seperti ini diserialisasi dalam format TriG dan dikueri dengan kata kunci `GRAPH` pada SPARQL 1.1 (Harris and Seaborne 2013). Mekanisme inilah yang memungkinkan dua hal yang dibutuhkan metode: (a) memisahkan pernyataan per sumber atau per *snapshot*, dan (b) menyaring pernyataan menurut metadata grafnya ketika menjawab pertanyaan *as-of* t (Subbab 3.6). Perlu dicatat bahwa RDF 1.1 tidak menetapkan semantik formal bagi hubungan antara nama graf dan isinya; makna "graf ini berasal dari laporan r" ditetapkan oleh konvensi ontologi penelitian (Subbab 3.5).

3.2 Ontologi dan Rekayasa Ontologi Berbasis *Competency Question*

3.2.1 Ontologi dan OWL 2

Penelitian ini memakai pendekatan berbasis pengetahuan (*knowledge-driven*), bukan pembelajaran mesin. Pada pembelajaran mesin, model belajar pola dari data latih. Pada pendekatan berbasis pengetahuan, peneliti berperan sebagai ahli domain yang mengeksplisitkan pengetahuannya, yaitu entitas keamanan siber dan relasinya, ke dalam struktur yang dimengerti mesin. Dengan demikian, tidak diperlukan tahap pelatihan. Kebenaran jawaban ditentukan oleh ketepatan skema: bila sebuah relasi salah

dimodelkan, kueri yang bergantung pada relasi itu akan memberi jawaban yang salah atau tidak lengkap. Karena itu, perancangan kelas dan relasi menjadi pusat metode.

Ontologi memberi makna pada IRI dalam KG dengan mendefinisikan kelas, properti, dan aksioma yang mengikatnya. OWL 2 (W3C OWL Working Group 2012) menyediakan bahasa untuk itu: kelas (`owl:Class`), properti objek dan properti data, hierarki (`rdfs:subClassOf`), serta batasan domain dan *range*. Dua sifat semantik OWL 2 relevan bagi rancangan. Pertama, OWL memakai *open-world assumption*: ketiadaan sebuah pernyataan tidak berarti pernyataan itu salah. Akibatnya, OWL tidak cocok untuk memeriksa kelengkapan data (misalnya "setiap pernyataan konteks wajib memiliki laporan"); pemeriksaan seperti itu diserahkan kepada SHACL (Subbab 3.7). Kedua, sifat yang sama menjadi dasar konseptual status `UNKNOWN` pada *exposure* aset (Subbab 3.8): ketiadaan data versi tidak boleh disimpulkan sebagai "tidak terdampak". Penalaran OWL dipakai terbatas untuk memeriksa konsistensi ontologi dengan *reasoner*, bukan untuk menurunkan jawaban CQ; jawaban CQ diturunkan secara deterministik dengan SPARQL.

3.2.2 Rekayasa ontologi berbasis CQ

Metodologi Noy and McGuinness (2001) menyusun ontologi secara iteratif: menentukan domain dan cakupan, mempertimbangkan *reuse* ontologi yang ada, mendaftar istilah penting, mendefinisikan kelas dan hierarkinya, mendefinisikan properti dan batasannya, lalu membuat instans. Cakupan ditetapkan dengan *competency question* (CQ), yaitu pertanyaan yang harus dapat dijawab oleh KG berbasis ontologi tersebut. CQ berfungsi ganda dalam penelitian ini. Pada tahap perancangan (tahap 4), CQ menjadi kriteria inklusi istilah: sebuah kelas atau properti hanya ditambahkan bila dibutuhkan oleh sedikitnya satu CQ, dan hubungannya dicatat dalam tabel *trace* istilah→CQ. Pada tahap evaluasi (tahap 10), CQ yang sama diterjemahkan menjadi kueri SPARQL yang jawabannya dibandingkan dengan *gold answer* (Subbab 3.10). Dengan demikian, ontologi tidak dinilai dari banyaknya konsep, tetapi dari kemampuannya menjawab CQ1–CQ8.

Langkah *reuse* dalam metodologi tersebut menjadi keputusan desain utama: ontologi aplikasi tidak dibangun dari nol, tetapi memperluas kosakata SEPSES dan ICS-SEC (Subbab 3.3) serta PROV-O (Subbab 3.5). Ekstensi hanya dibuat untuk konsep yang belum ada: laporan, sektor/negara sasaran, validitas waktu, dan *provenance* per laporan.

3.2.3 Validasi ontologi dengan OOPS!

OOPS! (Poveda-Villalón et al. 2014) adalah pemindai yang mendeteksi *pitfall* umum pada ontologi, misalnya elemen tanpa anotasi, properti tanpa domain atau *range*, siklus hierarki, dan penggunaan relasi yang keliru, serta mengelompokkannya menurut tingkat kepentingan (kritis, penting, minor). Alat ini juga dipakai dalam pengembangan ICS-SEC KG (Kurniawan, Kiesling, Winkler, et al. 2024), sehingga pemakaiannya men-

jaga keselarasan praktik dengan ekosistem SEPSES. OOPS! memeriksa kualitas struktur ontologi, bukan kebenaran data; keduanya dilengkapi oleh SHACL dan evaluasi CQ.

3.3 Kosakata SEPSES dan ICS-SEC

SEPSES *Cybersecurity Knowledge Graph* (Kiesling et al. 2019) mengintegrasikan sumber pengetahuan keamanan publik ke dalam RDF dengan kosakata per sumber: `cve:` (kerentanan), `cpe:` (identitas produk), `cvss:` (metrik keparahan), `cwe:` (kelemahan), dan `capec:` (pola serangan). Rantai yang relevan bagi penelitian ini adalah aset→CPE→CVE→CVSS/CWE/CAPEC. Rantai ini memungkinkan penilaian kerentanan berbasis aset: produk aset dicocokkan dengan CPE, CPE dihubungkan ke CVE melalui `cve:hasCPE`, lalu CVE diperkaya dengan skor CVSS, kelas CWE, dan pola CAPEC. Rantai ini menjadi skenario pembanding B0 (SEPSES-saja) dan sumber jawaban CQ1–CQ2. Batasnya, SEPSES tidak memuat konsep aktor, kampanye, sektor sasaran, atau waktu aktivitas ancaman, sehingga CQ3–CQ8 tidak dapat dijawab.

ICS-SEC KG (Kurniawan, Kiesling, Winkler, et al. 2024) memperluas ekosistem ini dengan kosakata `attack:` untuk MITRE ATT&CK. Repositori publiknya (SEPSES Team 2024) menunjukkan bahwa data ATT&CK yang berformat STIX dipetakan ke RDF dengan berkas RML `cat-json.rml`. Pola pemetaannya menjadi titik awal integrasi penelitian ini:

- setiap objek STIX menjadi instans `attack:{type}` dengan IRI `http://w3id.org/sepses/resource/attack/{id}`;
- setiap relasi STIX menjadi *resource* tersendiri dengan `attack:relationshipType`, `attack:hasSourceRef`, dan `attack:hasTargetRef`;
- metadata memakai `dcterm:created`, `dcterm:modified`, `dcterm:title`, dan `dcterm:description`, sedangkan referensi memakai `attack:hasReference`.

Karena relasi STIX sudah direpresentasikan sebagai *resource*, pernyataan seperti "*intrusion set* X menargetkan kerentanan Y" dapat diberi metadata tanpa mengubah pola SEPSES. Namun, pemetaan tersebut dirancang untuk ATT&CK sebagai *data referensi statis*. Ia belum mencakup atribut CTI operasional yang bertanggal: `report` beserta `object_refs`, `published`, `created_by_ref`, `valid_from`/`valid_until`, `revoked`, `confidence`, identitas sektor, *location*, dan *indicator*. Celah inilah yang diisi oleh kontribusi K1. Implementasinya dapat berupa perluasan `cat-json.rml` atau implementasi Python dengan IRI dan kosakata yang identik **[Diskusi: RML/Java atau Python? (keputusan G-2)]**.

3.4 STIX 2.1 dan OpenCTI

3.4.1 Model objek dan relasi STIX 2.1

STIX 2.1 (Jordan et al. 2021) adalah standar pertukaran CTI berbasis JSON. Model datanya terdiri atas *STIX Domain Object* (SDO), misalnya `report`, `intrusion-set`, `malware`, `attack-pattern`, `vulnerability`, `identity`, `location`, dan `indicator`; *STIX Relationship Object* (SRO), yaitu `relationship` dengan `source_ref`, `target_ref`, dan `relationship_type` (misalnya `targets` atau `uses`); serta *STIX Cyber-observable Object* untuk artefak teknis. Struktur ini sudah berbentuk graf, sehingga pemetaan ke RDF secara struktural lugas. Kesulitannya terletak pada semantik waktu dan asal-usul yang melekat pada atribut berikut.

Tabel 3.1. Atribut STIX 2.1 yang menentukan *provenance* dan waktu

Atribut	Makna dan peran dalam penelitian
`created`	Waktu versi pertama objek dibuat oleh pembuatnya. Bukan waktu kejadian ancaman.
`modified`	Waktu versi objek ini dibuat. Pasangan (`id`, `modified`) mengidentifikasi satu versi.
`published`	(khusus `report`) Waktu laporan diterbitkan secara resmi. Menjadi waktu publikasi bukti pada Subbab 3.6.
`object_refs`	(khusus `report`) Daftar objek dan relasi yang dimuat atau dirujuk laporan. Menjadi dasar *provenance* per laporan.
`created_by_ref`	Rujukan ke `identity` pembuat objek. Menjadi agen pada PROV-O.
`valid_from`/`valid_until`	(khusus `indicator`) Rentang waktu *indicator* dianggap berlaku.
`revoked`	Penanda bahwa objek dicabut oleh pembuatnya dan tidak boleh dipakai lagi.
`external_references`	Rujukan luar, misalnya ID CVE atau ID ATT&CK (Txxxx/Gxxxx/Sxxxx). Menjadi dasar *entity linking*.

Tabel 3.1 memperlihatkan bahwa STIX membedakan beberapa jenis waktu, tetapi tidak satu pun menyatakan secara langsung "sejak kapan sebuah asosiasi aktor–CVE dapat diketahui analis". Sebuah `relationship` memiliki `created` miliknya sendiri, tetapi asosiasi itu baru tersedia secara publik ketika laporan yang memuatnya melalui `object_refs` diterbitkan. Karena itu, penelitian ini menurunkan waktu bukti dari `published` laporan, bukan dari `created` relasi **[Diskusi: konfirmasi: `published` laporan sebagai waktu bukti utama]**. Satu relasi dapat dirujuk oleh beberapa laporan, sehingga sebuah pernyataan dapat memiliki beberapa bukti dengan waktu berbeda.

3.4.2 OpenCTI sebagai sumber data

OpenCTI adalah platform pengelolaan CTI yang menyimpan dan mengekspor data dalam model STIX 2.1 dan menghimpun data dari berbagai konektor; platform ini juga telah dipakai dalam penelitian atribusi ancaman (S. Ruohonen et al. 2024). Data penelitian ini berasal dari ekspor OpenCTI dengan konektor AlienVault: 573.967 objek STIX 2.1, 986 laporan (5 Februari–30 Desember 2025), 352 CVE, dan hanya 2 identitas `created_by`. Jumlah pembuat yang sangat sedikit menunjukkan bahwa `created_by_ref` saja tidak cukup untuk menelusuri asal pernyataan; jejak yang informatif adalah laporan beserta waktu terbitnya. Hal ini memperkuat pilihan *provenance* per laporan pada Subbab 3.5. Konfigurasi konektor juga menentukan asal relasi. Sebagian relasi dinyatakan oleh sumber, sedangkan sebagian lain diturunkan oleh konektor, misalnya relasi *indicator→attack-pattern*. Perbedaan ini dijelaskan pada Subbab 4.2.2.

3.5 *Provenance*: PROV-O dan Pola Representasi Pernyataan

3.5.1 PROV-O

PROV-O (Lebo et al. 2013) adalah ontologi W3C untuk *provenance* dengan tiga kelas inti: `prov:Entity` (sesuatu yang ada, misalnya laporan atau graf pernyataan), `prov:Activity` (proses yang menghasilkan atau memakai entitas, misalnya ekspor atau transformasi), dan `prov:Agent` (pihak yang bertanggung jawab, misalnya identitas pembuat laporan). Properti yang dipakai penelitian ini adalah `prov:wasAttributedTo` (entitas→agen), `prov:generatedAtTime` (waktu entitas dihasilkan), `prov:wasDerivedFrom` (entitas→entitas sumber), dan `prov:wasGeneratedBy` (entitas→aktivitas). Pemetaannya ke STIX langsung: `created_by_ref` menjadi `prov:wasAttributedTo`, `published` menjadi `prov:generatedAtTime`, dan hubungan pernyataan dengan laporan sumbernya menjadi `prov:wasDerivedFrom`. Pemakaian kosakata standar ini membuat CQ6 (laporan, pembuat, waktu, dan referensi pendukung setiap pernyataan) dapat dijawab dengan kueri yang seragam dan membuat kelengkapan jejak dapat diukur (U3).

3.5.2 Dua pola mengaitkan metadata dengan pernyataan

PROV-O menjelaskan *apa* yang dicatat, tetapi tidak menentukan *bagaimana* metadata ditempelkan pada sebuah *triple*. Ada dua kandidat pola.

(a) *Named graph* per laporan. Semua pernyataan yang berasal dari satu laporan dimasukkan ke graf bernama n_r, lalu metadata dinyatakan tentang n_r:

```
GRAPH ex:g-report-123 {
  attack:rel-456 attack:relationshipType "targets" ;
                 attack:hasSourceRef attack:intrusion-set--abc ;
                 attack:hasTargetRef cve:CVE-2025-0001 .
```

```
}
ex:g-report-123 prov:wasDerivedFrom attack:report--123 ;
                prov:generatedAtTime "2025-08-14T00:00:00Z"^^xsd:dateTime ;
                prov:wasAttributedTo attack:identity--xyz .
```

Kelebihannya, pola ini sepenuhnya standar RDF 1.1 dan SPARQL 1.1, satu filter pada metadata graf cukup untuk memilih seluruh pernyataan yang *admissible*, dan skenario ablation "tanpa filter waktu" mudah diwujudkan dengan mengabaikan filter tersebut. Kekurangannya, satu pernyataan yang dirujuk beberapa laporan harus diulang di beberapa graf.

(b) RDF-star. RDF-star (Hartig et al. 2021) memperluas RDF sehingga sebuah *triple* dapat menjadi subjek *triple* lain (*quoted triple*). Pola inilah yang dipakai ICS-SEC KG untuk mengaitkan referensi dengan sebuah relasi (Kurniawan, Kiesling, Winkler, et al. 2024):

```
<< attack:intrusion-set--abc ext:targetsVulnerability cve:CVE-2025-0001 >>
    prov:wasDerivedFrom attack:report--123 ;
    attack:hasReference ex:ref-789 .
```

Kelebihannya, metadata melekat langsung pada pernyataan tanpa mengulang *triple*, dan polanya selaras dengan ICS-SEC. Kekurangannya, RDF-star belum menjadi bagian RDF 1.1 dan dukungannya bergantung pada *triplestore*. Prefiks `ext:` pada contoh menandai istilah ekstensi yang belum final.

Kedua pola dapat menjawab CQ6 dan dapat dinilai dengan ukuran U3 yang sama. Kriteria pemilihannya adalah kemudahan kueri *as-of* t dan dukungan *triplestore* **[Diskusi: RDF-star (selaras ICS-SEC) atau named graph per laporan? keputusan G-2]**.

3.6 Waktu dan Keabsahan Bukti (*Admissibility*)

3.6.1 Tiga jenis waktu

Penilaian kerentanan selalu dilakukan pada suatu waktu keputusan t. Agar jawaban *as-of* t benar, tiga jenis waktu harus dibedakan:

1. **Waktu publikasi**, yaitu kapan sebuah bukti dinyatakan oleh pembuatnya (pada STIX: `published` laporan).
2. **Waktu ketersediaan**, yaitu kapan bukti itu benar-benar dapat diakses analis, misalnya saat diserap ke OpenCTI. Waktu ini dapat lebih lambat daripada waktu publikasi dan umumnya tidak teramati pada satu *snapshot* ekspor.
3. **Waktu validitas**, yaitu rentang ketika isi bukti dianggap berlaku (pada STIX: `valid_from`/`valid_until` untuk *indicator*, serta status `revoked`).

Penelitian ini memakai waktu publikasi sebagai pendekatan waktu ketersediaan karena hanya waktu itu yang tersedia secara konsisten **[Diskusi: perlu dibahas: apakah waktu**

penyerapan (*ingest*) ke OpenCTI dapat dipakai sebagai waktu ketersediaan?]. Konsekuensinya, jawaban *as-of* t bersifat optimistis: bukti yang terbit sebelum t dianggap sudah dapat diketahui pada t.

3.6.2 Definisi formal

Misalkan e sebuah pernyataan konteks ancaman, misalnya asosiasi *intrusion set*–CVE, dan $\mathcal{B}(e)$ himpunan bukti yang mendukungnya, yaitu laporan yang memuat e melalui `object_refs`. Untuk setiap bukti $b \in \mathcal{B}(e)$ didefinisikan $pub(b)$ sebagai waktu publikasi, $rev(b,t)$ bernilai benar bila b (atau objek yang dirujuknya) sudah berstatus `revoked` pada versi terakhir yang `modified`-nya $\leq t$, dan $vu(b)$ sebagai `valid_until` bila ada. Himpunan bukti yang sah pada waktu t adalah

$$\mathcal{B}_t(e) = \Big\{ b \in \mathcal{B}(e) \;\Big|\; pub(b) \leq t \;\wedge\; \neg\, rev(b,t) \;\wedge\; \Big(vu(b) \text{ tidak ada } \vee\; vu(b) > t \Big) \Big\}. \tag{3-3}$$

Pernyataan e *sah-waktu* (*admissible*) pada waktu t dengan jendela kebaruan W bila memiliki bukti sah dan bukti sah terbarunya tidak lebih tua dari W:

$$admissible(e,t,W) \iff \mathcal{B}_t(e) \neq \emptyset \;\wedge\; t - \max_{b \in \mathcal{B}_t(e)} pub(b) \leq W. \tag{3-4}$$

Persamaan (3-3)–(3-4) memuat empat syarat yang dirumuskan pada metode: bukti sudah terbit per t, tidak dicabut per t, masih berlaku per t bila memiliki `valid_until`, dan bukti terbarunya berada dalam jendela W. Syarat `valid_until` praktis hanya mengenai *indicator*. Rekonstruksi status `revoked` per t dari satu *snapshot* bergantung pada tersedianya versi lama objek **[Diskusi: apakah ekspor OpenCTI menyimpan riwayat versi?]**.

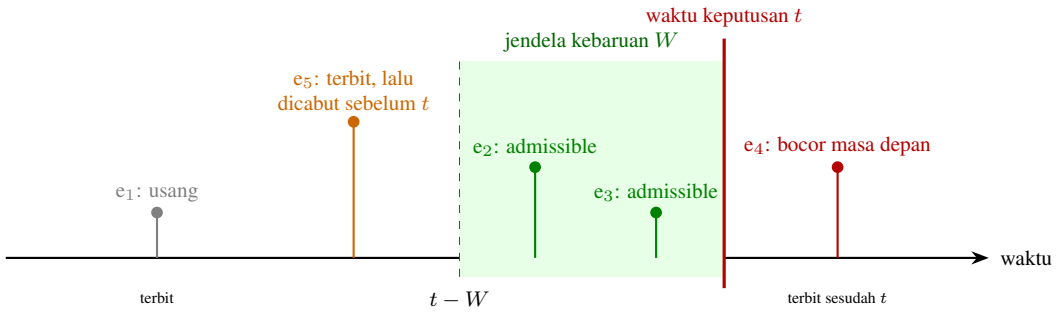
Dari definisi tersebut diturunkan dua jenis kesalahan yang diukur oleh U2. *Kebocoran masa depan* terjadi bila sebuah jawaban *as-of* t memuat e padahal tidak ada bukti yang terbit sampai t:

$$leak(e,t) \iff \mathcal{B}(e) \neq \emptyset \;\wedge\; \forall b \in \mathcal{B}(e) :\; pub(b) > t. \tag{3-5}$$

Bukti usang terjadi bila e memiliki bukti sah, tetapi bukti terbarunya sudah lebih tua dari jendela W:

$$stale(e,t,W) \iff \mathcal{B}_t(e) \neq \emptyset \;\wedge\; t - \max_{b \in \mathcal{B}_t(e)} pub(b) > W. \tag{3-6}$$

Sebuah jawaban dikatakan memuat bukti tidak sah-waktu (*inadmissible*) bila sedikitnya satu pernyataan di dalamnya tidak memenuhi Persamaan (3-4), baik karena bocor, usang, maupun dicabut. Gambar 3.1 mengilustrasikan ketiga kategori pada garis waktu.



Gambar 3.1. Ilustrasi *admissibility* bukti CTI pada waktu keputusan t. Hanya e_2 dan e_3 yang boleh dipakai: e_1 usang (di luar jendela W), e_4 belum tersedia pada t, dan e_5 sudah dicabut. Integrasi naif yang mengabaikan waktu akan memakai kelimanya.

Definisi ini bukan sekadar formalitas. Pada data penelitian, bila waktu diabaikan, 3.789 dari 8.281 relasi `targets` ke *vulnerability* (45,8%) berasal dari laporan yang terbit sesudah t = 30 September 2025, dan pada t = 31 Desember 2025 dengan W = 90 hari, 4.256 relasi (51,4%) tergolong usang. Integrasi naif (B1) memperlakukan semua relasi itu sebagai konteks yang berlaku. Persamaan (3-4) diwujudkan pada tahap 6 sebagai template SPARQL parametrik dengan parameter t dan W, dan menjadi dasar CQ5 serta CQ7–CQ8. Nilai W ditetapkan di muka: 180 hari sebagai nilai utama dan 90 hari untuk analisis sensitivitas **[Diskusi: nilai W perlu justifikasi rujukan]**.

3.7 Validasi Data dengan SHACL

SHACL (Knublauch and Kontokostas 2017) adalah bahasa W3C untuk memvalidasi graf RDF terhadap sekumpulan *shape*. Sebuah *node shape* memilih *focus node* melalui *target* (misalnya `sh:targetClass`), lalu *property shape* di dalamnya menetapkan *constraint* pada nilai properti, misalnya kardinalitas (`sh:minCount`, `sh:maxCount`), tipe data (`sh:datatype`), dan kelas nilai (`sh:class`). Hasil validasi adalah *validation report* dengan `sh:conforms` bernilai `true` atau `false` serta daftar pelanggaran per *focus node*. Contoh berikut mewajibkan setiap graf pernyataan memiliki tepat satu waktu publikasi dan sedikitnya satu laporan sumber:

```
ex:StatementGraphShape a sh:NodeShape ;
  sh:targetClass ext:StatementGraph ;
  sh:property [ sh:path prov:generatedAtTime ;
                sh:datatype xsd:dateTime ; sh:minCount 1 ; sh:maxCount 1 ] ;
  sh:property [ sh:path prov:wasDerivedFrom ;
                sh:class attack:report ; sh:minCount 1 ] .
```

Berbeda dengan OWL, SHACL bekerja dengan asumsi dunia tertutup terhadap data yang divalidasi: properti yang tidak ada dianggap pelanggaran. Sifat ini tepat untuk menegakkan kelengkapan *provenance*, sehingga SHACL dipakai pada tahap 4 untuk ontologi beserta *fixture* positif dan negatif, dan hasilnya menjadi bagian U3: data valid harus menghasilkan 0 pelanggaran dan *fixture* negatif harus ditolak.

3.8 *Exposure* Aset

3.8.1 CPE 2.3 dan rentang versi

CPE 2.3 menamai produk TI dengan string terformat `cpe:2.3:part:vendor:product:version:update:edition:language:sw_edition:target_sw:target_hw:other`, dengan `part` bernilai `a` (aplikasi), `o` (sistem operasi), atau `h` (perangkat keras), serta nilai khusus $\star$ (apa saja) dan $-$ (tidak berlaku) **[Diskusi: rujukan: spesifikasi CPE 2.3 (NISTIR 7695)]**. SEPSES menautkan CVE ke CPE melalui `cve:hasCPE` (Kiesling et al. 2019). Rekaman CVE List v5 memakai struktur lain, yaitu daftar `affected` yang memuat `vendor`, `product`, dan `versions`. Setiap entri versi dapat berupa versi tunggal atau rentang (`version` sebagai batas bawah, `lessThan` atau `lessThanOrEqual` sebagai batas atas) dengan `status` `affected`/`unaffected`/`unknown`, `versionType` yang menentukan cara membandingkan versi, dan `defaultStatus` untuk versi yang tidak disebut **[Diskusi: rujukan: skema CVE JSON 5]**. Hanya 7,71% rekaman CVE List v5 yang memuat CPE eksplisit, sehingga pencocokan berbasis CPE saja akan kehilangan sebagian besar CVE baru. Karena itu, metode pada tahap 6 memakai keduanya: CPE bila tersedia, dan `affected`/rentang versi bila tidak.

3.8.2 Logika tiga nilai

Pencocokan aset dengan CVE tidak selalu dapat diputuskan. Data versi aset dapat tidak lengkap, rentang versi dapat memakai skema yang tidak dapat dibandingkan, atau rekaman CVE tidak memuat data produk yang memadai. Mengikuti *open-world assumption* (Subbab 3.2), kasus seperti ini tidak boleh dipaksa menjadi "tidak terdampak". Status *exposure* aset a terhadap CVE v karena itu bernilai dalam himpunan $\{\mathrm{TRUE}, \mathrm{UNKNOWN}, \mathrm{FALSE}\}$ dengan urutan $\mathrm{FALSE} < \mathrm{UNKNOWN} < \mathrm{TRUE}$. Operator logika mengikuti logika tiga nilai Kleene yang kuat:

$$\begin{aligned} x \wedge y = \min(x, y), \qquad x \vee y = \max(x, y), \\ \neg\,\mathrm{TRUE} = \mathrm{FALSE}, \quad \neg\,\mathrm{UNKNOWN} = \mathrm{UNKNOWN}, \end{aligned} \tag{3-7}$$

[Diskusi: rujukan: logika tiga nilai Kleene]. Untuk satu aset, status terhadap v adalah disjungsi atas semua entri `affected` yang relevan: $exp(a, v) = \bigvee_k match_k(a, v)$. Sebuah entri bernilai TRUE bila produk cocok dan versi aset berada dalam rentang berstatus `affected`; FALSE bila produk tidak cocok, atau produk cocok tetapi versi berada di luar rentang dan status bawaannya `unaffected`; dan UNKNOWN untuk sisanya. Status ini menjadi jawaban CQ1 beserta dasar pencocokannya, dan dimensi pertama tabel tier (Subbab 3.9).

3.9 Tabel Keputusan Prioritas dan Sinyal Pembanding

3.9.1 SSVC sebagai model keputusan

SSVC (Spring et al. 2019) mengusulkan prioritisasi kerentanan sebagai *decision tree* kualitatif, bukan skor numerik. Setiap *decision point* memiliki sedikit nilai diskret, misalnya status eksploitasi, dan kombinasi nilai tersebut dipetakan ke *outcome* berupa tindakan (misalnya tunda, jadwalkan, atau segera tangani). Kelebihan pendekatan ini bagi penelitian adalah transparansi: setiap *outcome* dapat dijelaskan dengan menyebut nilai *decision point* yang menghasilkannya. Sifat ini sejalan dengan tuntutan ketertelusuran (U3) dan dengan batasan penelitian yang memakai penalaran deterministik tanpa model terlatih.

Penelitian ini meminjam bentuk SSVC, bukan *decision point*-nya secara utuh. Tabel tier (CQ8) memakai tiga dimensi yang masing-masing diturunkan dari teori di bab ini: *exposure* TRUE/UNKNOWN (Subbab 3.8), status KEV per t, dan relevansi ancaman. Relevansi ancaman bernilai 1 bila ada laporan sah-waktu (Persamaan (3-4)) yang memuat CVE tersebut sekaligus sektor atau wilayah organisasi. Relevansi sengaja diikat pada satu laporan, bukan ditelusuri secara transitif melalui aktor atau *malware*, karena aktor umumnya menyasar banyak sektor sehingga penelusuran transitif hampir selalu bernilai 1 (Subbab 4.6.3). Secara formal, tabel tier adalah fungsi total

$$tier : \{\text{TRUE}, \text{UNKNOWN}\} \times \{0,1\} \times \{0,1\} \to \mathcal{T}, \tag{3-8}$$

dengan $\mathcal{T}$ himpunan tier terurut. Karena domainnya hanya 8 kombinasi, setiap baris dapat ditetapkan dan dibekukan sebelum evaluasi, dan setiap tier dapat ditelusuri ke bukti yang membentuk nilai ketiga dimensinya **[Diskusi: isi dan jumlah tier dibahas di Bab IV]**.

3.9.2 KEV, CVSS, dan EPSS

Katalog KEV (Cybersecurity and Infrastructure Security Agency 2026) mendaftar CVE yang diketahui telah dieksploitasi, masing-masing dengan tanggal masuk (`dateAdded`). Tanggal itu membuat status KEV dapat dievaluasi per t (CQ7): sebuah CVE berstatus KEV pada t bila $dateAdded \leq t$. Tanpa syarat ini, status KEV pun akan bocor dari masa depan. Pada data penelitian, 204 dari 352 CVE ada di KEV, dan pada 175 di antaranya laporan CTI pertama terbit pada atau sesudah `dateAdded` dengan median selisih +379 hari. KEV bersifat biner dan tidak menyatakan aktor, sektor, atau kebaruan; inilah yang dilengkapi oleh dimensi relevansi ancaman.

CVSS (Forum of Incident Response and Security Teams 2019) mengukur keparahan teknis kerentanan dari metrik dasar seperti vektor serangan, kompleksitas, hak akses yang dibutuhkan, dan dampak kerahasiaan/integritas/ketersediaan. Skor dasarnya tidak bergantung pada konteks ancaman organisasi. EPSS (Jacobs, Romanosky, Edwa-

rds, et al. 2021) memperkirakan peluang sebuah CVE dieksploitasi dalam jendela waktu tertentu berdasarkan fitur kerentanan dan data eksploitasi teramati, tetapi peluang itu bersifat global, bukan khusus sektor atau wilayah. Dalam penelitian ini CVSS hanya menjadi atribut jawaban CQ2 dan sinyal pembanding, sedangkan EPSS hanya menjadi pembanding deskriptif pada studi kasus (U5). Keduanya tidak menjadi *decision point* tier, dan penelitian ini tidak mengklaim ranking yang lebih akurat daripada keduanya.

3.10 Teori Evaluasi

3.10.1 *Precision*, *recall*, dan F1 untuk jawaban kueri

Jawaban sebuah CQ untuk satu instans pertanyaan q (misalnya satu CVE pada satu waktu t) adalah himpunan hasil A_q, sedangkan *gold answer*-nya adalah G_q. Kebenaran jawaban diukur dengan

$$P_q = \frac{|A_q \cap G_q|}{|A_q|}, \qquad R_q = \frac{|A_q \cap G_q|}{|G_q|}, \qquad F1_q = \frac{2\,P_q R_q}{P_q + R_q}. \tag{3-9}$$

Precision turun bila sistem memasukkan konteks yang tidak didukung bukti, misalnya pernyataan yang bocor dari masa depan pada B1. *Recall* turun bila konteks yang benar terlewat, misalnya karena *entity linking* gagal. Dengan demikian, kesalahan waktu dan kesalahan penautan (*coverage*) tercermin pada komponen yang berbeda. Kesalahan audit diukur terpisah oleh U3. Untuk kasus $A_q = G_q = \emptyset$ (CVE yang memang tidak memiliki konteks), $P_q = R_q = F1_q = 1$; bila hanya salah satunya kosong, nilai yang tidak terdefinisi ditetapkan 0 **[Diskusi: konvensi himpunan kosong perlu disepakati]**.

3.10.2 F1 makro

Untuk CQ c dengan himpunan instans Q_c, nilai per CQ adalah rerata $F1_c = \frac{1}{|Q_c|}\sum_{q \in Q_c} F1_q$. F1 makro adalah rerata tanpa bobot atas CQ yang dievaluasi:

$$F1_{\text{makro}} = \frac{1}{|C|}\sum_{c \in C} F1_c. \tag{3-10}$$

Rerata makro dipilih agar CQ dengan banyak instans tidak menutupi CQ yang lebih sulit tetapi berinstans sedikit, misalnya CQ4 tentang sektor dan wilayah. Target usulan U1 adalah $F1_{\text{makro}} \geq 0{,}90$ pada *test set* **[Diskusi: rerata per instans atau F1 mikro per CQ?]**.

3.10.3 Selang kepercayaan *bootstrap*

Gold standard usulan berukuran kecil (60 CVE: 20 *dev*, 40 *test*), sehingga estimasi titik F1 perlu disertai ketidakpastiannya. *Bootstrap* persentil memperkirakannya tanpa asumsi distribusi **[Diskusi: rujukan bootstrap]**. Dari *test set* berisi n CVE diambil B

sampel ulang berukuran n dengan pengembalian; unit sampel ulang adalah CVE, sehingga seluruh instans CQ milik satu CVE ikut terambil bersama. Untuk setiap sampel ulang b dihitung $F1^{(b)}_{\text{makro}}$, dan selang kepercayaan 95% adalah

$$\text{CI}_{95\%} = \left[F1^{(2{,}5\%)}_{\text{makro}},\ F1^{(97{,}5\%)}_{\text{makro}} \right], \tag{3-11}$$

dengan $F1^{(\alpha)}$ sebagai persentil ke-α dari distribusi *bootstrap*. Kriteria keputusan U1 memakai batas bawah selang ini: usulan dinilai lebih baik daripada B1 bila batas bawah CI usulan melampaui F1 B1.

3.10.4 Cohen's κ

Gold answer dibuat oleh peneliti dari JSON STIX mentah dan katalog KEV, bukan dari keluaran *pipeline*. Untuk mengendalikan subjektivitasnya, 20% sampel dianotasi ulang oleh anotator kedua, dan kesepakatannya diukur dengan Cohen's κ (Cohen 1960):

$$\kappa = \frac{p_o - p_e}{1 - p_e}, \qquad p_e = \sum_k p_{1k}\, p_{2k}, \tag{3-12}$$

dengan p_o proporsi butir yang disepakati, dan p_{1k}, p_{2k} proporsi butir yang diberi kategori k oleh anotator pertama dan kedua. Koreksi p_e penting karena sebagian keputusan anotasi bersifat biner dan tidak seimbang (misalnya "apakah aktor ini relevan dengan sektor X"), sehingga kesepakatan mentah akan tampak tinggi meskipun terjadi secara kebetulan. Target usulan adalah $\kappa \geq 0{,}80$.

3.11 Hubungan Teori dengan Rancangan Penelitian

Tabel 3.2 merangkum peran setiap teori. Nomor tahap mengacu pada bagan alir penelitian di Bab IV (Gambar 4.3).

Tabel tersebut juga berfungsi sebagai pemeriksaan arah sebaliknya: setiap komponen metode di Bab IV, yaitu ontologi, pemetaan, *entity linking*, *named graph*, *admissibility*, *exposure*, tier, dan evaluasi, telah memiliki dasar teoretis di bab ini. Teori yang tidak dipakai metode, seperti ekstraksi CTI dari teks bebas atau model prediksi eksploitasi, sengaja tidak dibahas karena berada di luar batasan penelitian.

Tabel 3.2. Hubungan teori dengan tahap metode dan ukuran keberhasilan

Teori (subbab)	Dipakai untuk	Tahap	Ukuran
RDF, *named graph* (3.1)	Dataset TriG per laporan/*snapshot*; *entity linking* melalui IRI bersama	5	U3, U4
Ontologi, CQ, OOPS! (3.2)	Ontologi aplikasi v0.2, tabel *trace* istilah→CQ, terjemahan CQ ke SPARQL	2, 4, 10	U1
SEPSES/ICS-SEC (3.3)	*Reuse* `attack:`/`cve:`/`cpe:`; perluasan `cat-json.rml`; skenario B0	4, 5	U1, U4
STIX 2.1, OpenCTI (3.4)	Pemetaan objek/relasi dan atribut waktu/*provenance*; linking via `external_references`	5	U1, U3
PROV-O, RDF-star/*named graph* (3.5)	Jejak laporan, pembuat, waktu per pernyataan (CQ6)	4, 5	U3
Admissibility (3.6)	Template SPARQL *as-of* t (CQ5, CQ7, CQ8); ablation tanpa filter waktu	6, 9	U2
SHACL (3.7)	*Shapes* dan *fixture* positif/negatif	4	U3
Exposure, logika tiga nilai (3.8)	Pencocokan aset–CVE TRUE/FALSE/UNKNOWN (CQ1)	6	U1, U4
SSVC, KEV, CVSS, EPSS (3.9)	Tabel tier transparan (CQ8); status KEV per t (CQ7); pembanding deskriptif	6, 10	U5
P/R/F1, *bootstrap*, κ (3.10)	Penilaian jawaban CQ terhadap *gold standard*; reliabilitas anotasi	7, 10	U1

BAB IV
METODE DAN RANCANGAN PENELITIAN

Bab ini menjelaskan bagaimana pertanyaan penelitian (RQ) pada Bab I dijawab secara operasional. Urutan uraiannya adalah sebagai berikut:

1. jenis penelitian (Subbab 4.1);
2. analisis kebutuhan data, infrastruktur akuisisi OpenCTI, perangkat, dan pengujian (Subbab 4.2);
3. bagan alir (Subbab 4.3);
4. rancangan ontologi dan integrasi, *competency question*, dan rancangan penalaran (Subbab 4.4–4.6);
5. desain eksperimen serta pemisahan *validation*, *testing*, dan *evaluation* (Subbab 4.7–4.8);
6. hasil pendahuluan, ancaman validitas, dan jadwal (Subbab 4.9–4.11).

Setiap komponen rancangan dikaitkan dengan salah satu ukuran keberhasilan U1–U5 sehingga benang merah antara kebutuhan, eksperimen, dan evaluasi dapat diperiksa. Seluruh ambang dan pilihan desain yang ditandai **[Diskusi: . . .]** masih berstatus usulan dan akan dibekukan bersama pembimbing sebelum *test set* dibuka.

4.1 Jenis dan Pendekatan Penelitian

Penelitian ini merupakan penelitian rekayasa dengan pendekatan *design-and-evaluate*: sebuah artefak dibangun, lalu diuji secara kuantitatif terhadap pembanding yang ditetapkan di muka. Artefak yang dibangun terdiri atas tiga bagian:

1. *application ontology* yang memperluas kosakata SEPSES (Kiesling et al. 2019; Kurniawan, Kiesling, Winkler, et al. 2024) untuk konteks ancaman STIX 2.1 (Jordan et al. 2021), lengkap dengan *provenance* (Lebo et al. 2013) dan atribut validitas waktu;
2. alur integrasi OpenCTI→SEPSES yang mencakup pemetaan, *entity linking*, dan pencatatan sumber per laporan;
3. penalaran deterministik berbasis aturan (SPARQL/SHACL) untuk *exposure* aset, *admissibility* bukti per waktu keputusan t, dan tier prioritas yang transparan.

Evaluasinya bersifat kuantitatif dan berbasis *competency question* (CQ) serta *gold standard*. Pilihan ini membedakan penelitian dari ICS-SEC KG, yang mengevaluasi melalui demonstrasi *use case* (Kurniawan, Kiesling, Winkler, et al. 2024). Penelitian ini *tidak* melatih model statistik. Oleh karena itu, peran *training* dalam pengertian pembelajaran mesin digantikan oleh pengembangan pemetaan dan aturan pada *development set*, sedangkan *test set* hanya dipakai sekali (Subbab 4.8).

Satu RQ dijawab dengan tiga kriteria keberhasilan: jawaban *benar* (U1), *sesuai waktu keputusan* (U2), dan *dapat ditelusuri sumbernya* (U3). Ukuran U4 (*coverage*) dan U5 (kegunaan) bersifat pendukung dan tidak menjadi syarat terjawabnya RQ.

4.2 Analisis Kebutuhan Penelitian

Analisis kebutuhan disusun sebelum rancangan arsitektur dan eksperimen agar setiap komponen rancangan memiliki dasar. Kebutuhan dikelompokkan ke dalam tiga pilar: data, perangkat, serta pengujian dan evaluasi.

4.2.1 Kebutuhan Data

Tabel 4.1 merangkum delapan sumber data (D1–D8). Setiap sumber akan diberi manifest yang memuat path, SHA-256, tanggal ambil, versi, lisensi, dan atribut waktu. Lisensi atau ketentuan pakai setiap sumber diverifikasi dan dicatat sebelum data dipublikasikan bersama artefak tesis.

Tabel 4.1. Kebutuhan data penelitian (D1–D8)

ID	Sumber dan isi	Status	Ukuran	Peran
D1	Ekspor OpenCTI (AlienVault OTX, STIX 2.1): laporan, relationship, intrusion-set, *malware*, attack-pattern, vulnerability, identity (sektor), location, *indicator*	Ada	573.967 objek; 986 laporan; 352 CVE	Konteks ancaman
D2	Seed converter SEPSES: CVE 2021–2024 (NVD 1.1), CPE, CWE, CAPEC, ATT&CK	Ada (lokal); tanpa manifest *retrieval*	24 file ($\pm$1 GB)	Lapisan kerentanan
D3	Dump SEPSES IFS TU Wien 2019	Ada	*snapshot* 2019	Referensi kosakata
D4	CVE List v5 2025–2026: *affected product*/versi, CVSS, CWE	Ada	90.255 file	Mengisi CVE baru
D5	Katalog CISA KEV (Cybersecurity and Infrastructure Security Agency 2026) (atribut `dateAdded`)	Ada (versi 2026.08.27)	1.685 entri	CQ7 dan tier
D6	Kosakata SEPSES/ICS-SEC dan pemetaan RML `cat-json.rml` (SEPSES Team 2024)	Perlu dipin ke *commit* tertentu **[Diskusi: status endpoint SEPSES]**	–	Target kompatibilitas
D7	Profil aset skenario: produk/versi, sektor, wilayah	Perlu disusun	2–3 profil; 20–40 aset	*Exposure* dan relevansi
D8	EPSS (Jacobs, Romanosky, Suciu, et al. 2023) (opsional)	Belum diakuisisi	–	Pembanding deskriptif

Atribut waktu menjadi kebutuhan inti karena kriteria U2 bergantung padanya. Atribut yang dipakai adalah `published`, `created`, `modified`, `valid_from`, `valid_until`, dan `revoked` pada D1; `datePublished` dan `dateUpdated`

pada D4; serta `dateAdded` pada D5. Ekspor D1 merupakan satu *snapshot*, sehingga histori revisi objek tidak direkonstruksi.

Profil aset D7 bukan CMDB nyata dan disebut sebagai *skenario*. Dua profil yang diusulkan adalah P1 instansi pemerintah (sektor Government) dan P2 perguruan tinggi (sektor Education). Aturan penyusunannya adalah sebagai berikut: produk dan versi diambil dari *affected product* CVE yang nyata sehingga muncul kasus TRUE, FALSE, dan UNKNOWN; asumsi setiap aset didokumentasikan; dan profil dibekukan *sebelum gold standard* dibuat. Wilayah Indonesia hanya muncul pada 5 pasangan CVE–lokasi, sehingga *sektor* menjadi dimensi relevansi utama dan wilayah menjadi dimensi sekunder. Keputusan apakah cukup memakai satu *feed*, perlu ekspor tahun lain, dan versi SEPSES mana yang menjadi target masih terbuka **[Diskusi: keputusan DATA-01: satu *feed* AlienVault 2025 atau tambah konektor/tahun?]**.

4.2.2 Infrastruktur Akuisisi Data: OpenCTI berbasis Docker

Data CTI (D1) diperoleh dari instans OpenCTI milik peneliti yang dijalankan dengan Docker Compose pada Docker Desktop (Apple Silicon), seperti ditunjukkan pada Gambar 4.2. OpenCTI di sini hanya berperan sebagai *sumber data*, bukan bagian dari metode yang diusulkan. Metode dimulai dari bundel STIX 2.1 hasil ekspor yang dibekukan beserta *checksum*-nya. Infrastruktur ini tetap perlu dijelaskan karena dua alasan.

Pertama, untuk reproduksibilitas. Pihak lain hanya dapat mengulang akuisisi data bila versi platform, konektor, dan konfigurasi impornya diketahui. *Kedua*, untuk *provenance*. Setiap konektor impor menentukan sumber dan identitas pembuat (`created_by_ref`) objek CTI, sehingga konektor merupakan *agent* dalam pengertian PROV-O. Konfigurasinya juga menentukan cakupan dan semantik data.

Komponen platformnya adalah sebagai berikut:

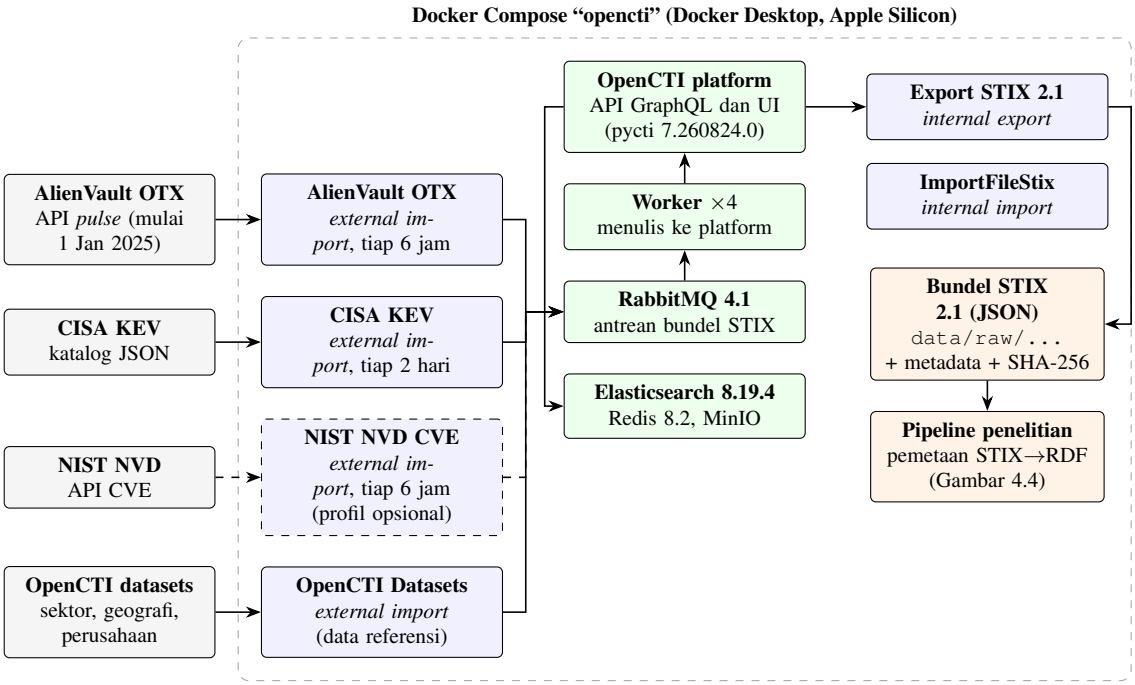
- OpenCTI *platform*;
- empat replika *worker*;
- RabbitMQ 4.1 sebagai antrean bundel;
- Elasticsearch 8.19.4 (simpul tunggal) sebagai penyimpanan dan indeks;
- Redis 8.2;
- MinIO untuk berkas.

Pustaka pycti pada *worker* dan konektor berversi 7.260824.0, dengan *image* dibuat 24–28 Agustus 2026. Seluruh *image* OpenCTI memakai tag `latest`. Karena itu, identitas *image* (*image ID*) dicatat dalam manifest artefak penelitian sebagai pengganti nomor versi. Untuk eksperimen tesis, versi akan dipatok (*pinned*). Tabel 4.2 merangkum konektor yang dipakai.

Konfigurasi tersebut menimbulkan empat konsekuensi metodologis.

Tabel 4.2. Konektor OpenCTI dan konfigurasi yang relevan bagi penelitian

Konektor	Tipe	Konfigurasi penting	Bukti pada data
AlienVault OTX	*external import*	`PULSE_START_TIMESTAMP` 2025-01-01; interval 6 jam; `GUESS_CVE` dan `GUESS_MALWARE` = `false`; `ENABLE_RELATIONSHIPS` dan `ENABLE_ATTACK_PATTERNS_INDICATES` = `true`; `CREATE_INDICATORS` = `true`; skor bawaan 50; TLP White	Pembuat 495.079 objek D1, termasuk 985/986 laporan dan seluruh 35.114 *indicator*
CISA KEV	*external import*	Katalog KEV resmi; interval 2 hari; `KEV_FLAG_ONLY` = `false`; TLP:CLEAR	Pembuat relasi pada ekspor terarah per CVE
NIST NVD CVE	*external import* (profil opsional)	Interval 6 jam; `PULL_HISTORY` = `false`; `IMPORT_SOFTWARE` = `false`	Tidak tampak sebagai pembuat objek pada data ekspor
OpenCTI Datasets	*external import*	Data referensi sektor, geografi, dan perusahaan dari repositori dataset OpenCTI; interval 7 hari	Entitas referensi sektor (62 kelas) dan lokasi
Export STIX 2.1	*internal export*	Format `application/json`	Metadata ekspor: waktu, cakupan `entity-and-first-neighbours`, TLP:CLEAR
ImportFileStix	*internal import*	Impor berkas STIX/XML manual; `AUTO` = `false`	Tidak dipakai untuk D1



Garis putus-putus: konektor NVD berada pada profil Compose opsional (`nvd`) dan tidak tampak sebagai pembuat objek pada data ekspor. Versi dan konfigurasi lengkap: Tabel 4.2.

Gambar 4.2. Infrastruktur akuisisi data CTI melalui OpenCTI berbasis Docker. OpenCTI hanya berperan sebagai sumber data; metode penelitian dimulai dari bundel STIX hasil ekspor.

1. **Cakupan waktu.** Laporan pada D1 hanya berasal dari tahun 2025 karena impor AlienVault dimulai 1 Januari 2025. Batas ini merupakan keputusan akuisisi, bukan sifat sumber, sehingga dinyatakan sebagai batasan.
2. **Asal relasi.** Dengan `GUESS_CVE` dan `GUESS_MALWARE` dinonaktifkan, tautan ke CVE dan *malware* berasal dari atribut eksplisit *pulse*, bukan tebakan dari teks. Sebaliknya, relasi *indicator→attack-pattern* (`indicates`, 321.204 relasi) diturunkan oleh konektor. Model *provenance* karena itu membedakan pernyataan yang dinyatakan sumber dari pernyataan turunan konektor.
3. **Keyakinan dan skor tidak diskriminatif.** Skor bawaan sama (50) dan *confidence* laporan seragam (100), sehingga keduanya tidak dipakai sebagai sinyal kualitas.
4. **Penggabungan objek.** OpenCTI menggabungkan (*merge*) objek yang sama dari beberapa konektor. Pekerjaan pendahuluan menemukan bahwa rantai asal dari NVD/CISA hanya tersisa sebagai *enrichment* atau *external reference*. Karena itu, *provenance* dibatasi pada tingkat yang teramati, yaitu laporan, pembuat, waktu, dan referensi. Asal sumber yang lebih jauh tidak diklaim.

Berkas `docker-compose.yml` (tanpa kredensial) dan manifest *image* diarsipkan bersama artefak penelitian.

4.2.3 Kebutuhan Perangkat

Penelitian tidak membutuhkan GPU karena tidak ada model terlatih. Kebutuhan utamanya adalah memori dan triplestore yang mampu menampung data berskala puluhan juta *triple*. Rinciannya ditunjukkan pada Tabel 4.3.

Tabel 4.3. Kebutuhan perangkat keras dan perangkat lunak

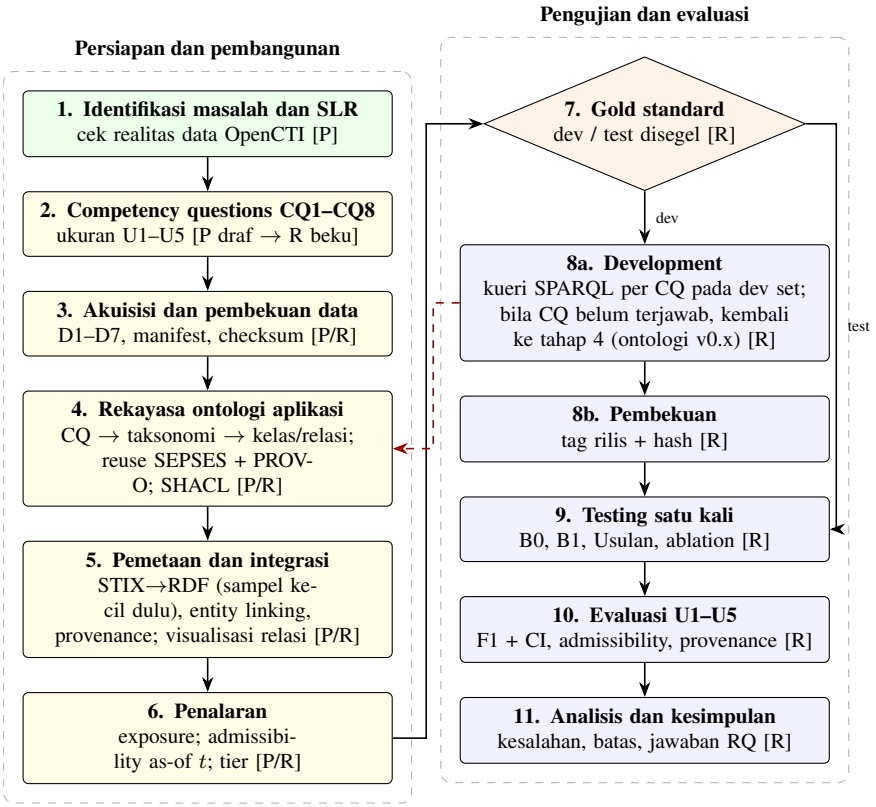
Kategori	Spesifikasi	Catatan
Perangkat keras	Laptop MacBook Pro milik mahasiswa; RAM $\geq$ 16 GB disarankan	Transformasi dilakukan secara *streaming*, tanpa memuat $\pm$560 MB JSON sekaligus
Bahasa/pustaka	Python 3.12; `rdflib` 7.x; `pyshacl`	Sama dengan pekerjaan pendahuluan; alternatif Java/RML **[Diskusi: lihat Subbab 4.4]**
Triplestore	Apache Jena Fuseki 5.6.0 (TDB2) di Docker, hanya terbuka di `localhost`	Estimasi $\pm$10–20 juta *triple*; `rdflib` *in-memory* tidak cukup. Sudah dipakai pada prototipe v0.1 (Subbab 4.9.2)
Ontologi	Protégé; reasoner HermiT/ELK; OOPS! (Poveda-Villalón et al. 2014)	Penyuntingan, cek konsistensi, dan deteksi *pitfall*
Platform CTI	Akses OpenCTI untuk ekspor ulang	Hanya bila DATA-01 memutuskan; bukan bagian metode
Penulisan	LaTeX DTETI, latexmk + Biber	–

4.2.4 Kebutuhan Pengujian dan Evaluasi

Ukuran keberhasilan ditetapkan sejak awal, bukan sesudah hasil diperoleh. Kebutuhan pengujian adalah sebagai berikut.

1. ***Gold standard*** berisi 60 CVE yang dibagi menjadi 20 *dev* dan 40 *test*, dengan anotasi yang diturunkan dari data mentah (bukan dari keluaran *pipeline*) dan anotator kedua untuk 20% sampel (Subbab 4.7).
2. **Pembanding** yang dapat dijalankan pada data yang sama: B0 SEPSES-saja, B1 integrasi naif, dan dua varian *ablation*.
3. **Metrik** U1–U5 yang masing-masing terkait dengan CQ tertentu (Tabel 4.5 dan Tabel 4.10).
4. **Fixture** SHACL (Knublauch and Kontokostas 2017) positif dan negatif untuk menguji bahwa *shapes* menerima data valid dan menolak data cacat.
5. **Log eksekusi**: hash rilis ontologi, pemetaan, aturan, dan tabel tier, serta hash daftar ID *dev*/*test*.

4.3 Bagan Alir Penelitian



Warna hijau: sudah ada (preliminary); kuning: sebagian ada dan dilanjutkan; biru: dikerjakan sesudah proposal disetujui. Panah merah putus-putus: iterasi ontologi bila CQ belum terjawab.

Gambar 4.3. Bagan alir penelitian. [P] = pekerjaan pendahuluan yang sudah ada; [R] = rencana tesis.

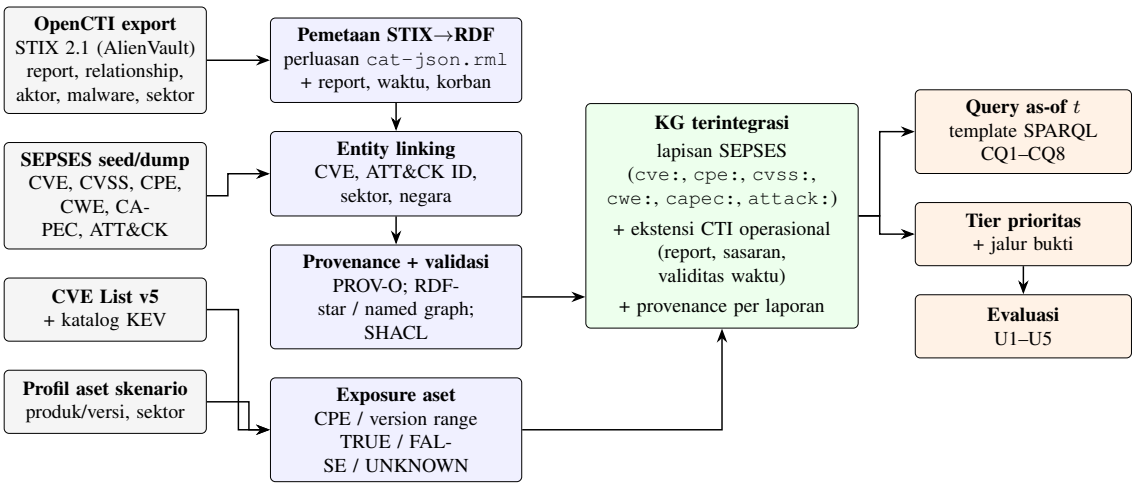
Gambar 4.3 menunjukkan sebelas tahap penelitian. Tanda **[P]** berarti *preliminary* (sudah dikerjakan dan dirujuk sebagai hasil pendahuluan), sedangkan **[R]** berarti rencana tesis yang dikerjakan sesudah proposal disetujui. Tiga tahap besar dapat dikenali: perencanaan dan pengumpulan data (tahap 1–3), pelaksanaan atau pembangunan artefak (tahap 4–6), serta pengujian dan evaluasi (tahap 7–11).

1. **Identifikasi masalah dan studi literatur [P]**. Pemetaan literatur dan cek realitas data OpenCTI. Keluarannya berupa sintesis literatur dan profil data (Subbab 4.9).
2. **Competency question dan kriteria keberhasilan [P draft → R beku]**. CQ1–CQ8 dan U1–U5 sudah dirumuskan dalam bentuk draf dan dibekukan pada minggu 1–2.
3. **Akuisisi dan pembekuan data [P sebagian → R]**. D1–D5 sudah tersedia secara lokal; manifest dan checksum dilengkapi, D6 dipin, dan profil aset skenario D7 disusun.
4. **Rekayasa ontologi aplikasi [P prototipe v0.1 → R v0.2 dst.]**. Dari setiap CQ disusun taksonomi, yaitu istilah dan entitas kunci yang muncul dalam pertanyaan, sebagai kandidat kelas. Taksonomi itu kemudian dilengkapi relasi antar-kelas. Kosakata SEPSES, PROV-O, dan konsep STIX dipakai ulang; SHACL dengan *fixture*; *trace* istilah→CQ (Tabel 4.4).
5. **Pemetaan dan integrasi [P sampel → R penuh]**. Pemetaan STIX→RDF dimulai dari sampel kecil agar setiap relasi dipahami; prototipe v0.1 dengan 7 laporan sudah dijalankan (Subbab 4.9.2). Hasil pemetaan divisualisasikan sebagai graf untuk memeriksa bahwa relasi pada Gambar 4.5 benar-benar terbentuk. Sesudah itu pemetaan diperluas ke 986 laporan, CVE List v5 dipetakan ke kosakata SEPSES, dan dilakukan *entity linking* serta pencatatan *provenance* per laporan.
6. **Penalaran [P exposure → R]**. *Exposure* aset, *admissibility* per waktu t, dan tier prioritas transparan.
7. ***Gold standard* [R]**. Pembagian *dev* dan *test* yang terpisah; daftar ID di-hash sebelum *pipeline* dievaluasi.
8. **Development dan validation, lalu pembekuan [R]**. (8a) Setiap CQ dijalankan sebagai kueri SPARQL pada *dev set*. Bila sebuah CQ belum terjawab, ontologi atau pemetaan diperbaiki dan diberi versi baru (v0.x), lalu tahap 4–6 diulang. Perbaikan aturan *linking* dan templat per waktu t juga hanya memakai *dev set*. (8b) Ontologi, pemetaan, aturan, dan tabel tier diberi tag rilis dan hash.
9. **Testing satu kali [R]**. B0, B1, Usulan, dan *ablation* dijalankan pada *test set* yang disegel.
10. **Evaluasi U1–U5 [R]**. F1 dengan selang kepercayaan, *admissibility*, kelengkapan *provenance*, *coverage*, dan studi kasus.

11. **Analisis kesalahan, batasan, dan kesimpulan [R]**. Kesalahan dikelompokkan menurut penyebabnya: *linking*, pemetaan, data sumber, atau aturan waktu.

Jalur *test set* pada Gambar 4.3 langsung menuju tahap 9 tanpa melewati tahap 8. Rancangan ini mencegah *data leakage*, yaitu perubahan metode berdasarkan informasi dari data uji (Arp et al. 2022).

4.4 Rancangan Ontologi dan Integrasi



Gambar 4.4. Arsitektur usulan integrasi CTI OpenCTI ke SEPSES Knowledge Graph. Pola provenance (RDF-star atau named graph) dan bahasa implementasi pemetaan masih didiskusikan.

Gambar 4.4 menunjukkan arsitektur integrasi. Lapisan kerentanan SEPSES (aset→CPE→CVE→CVSS/CWE/CAPEC) dipertahankan, lalu ditambah lapisan konteks ancaman dari OpenCTI dan lapisan *provenance*/waktu.

4.4.1 Penggunaan Ulang Kosakata SEPSES/ICS-SEC

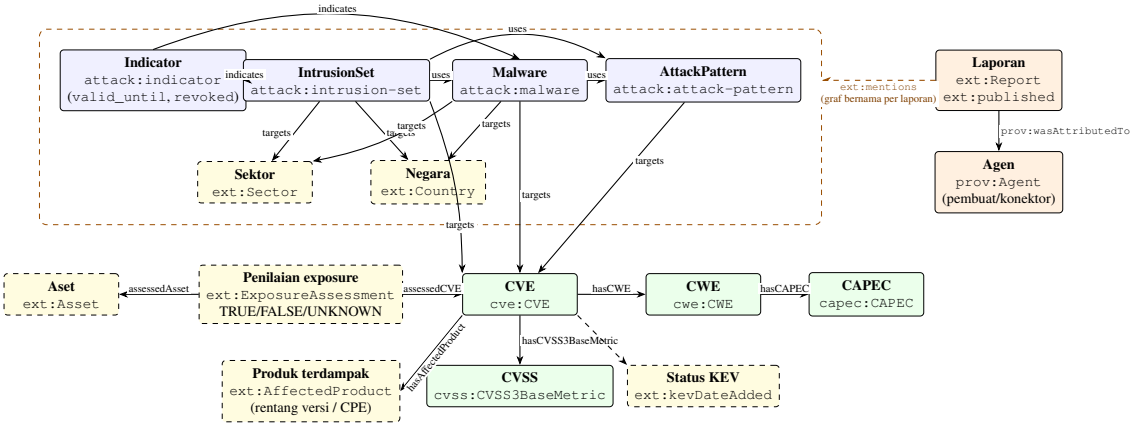
Ontologi dikembangkan dengan metode Noy and McGuinness (2001) yang dipandu CQ (dasar teorinya pada Subbab 3.2 dan 3.3). Prinsip utamanya adalah *reuse* sebelum membuat istilah baru. Kosakata yang dipakai ulang adalah `attack:`, `cve:`, `cpe:`, `cvss:`, `cwe:`, `capec:`, dan DCMI terms dari SEPSES/ICS-SEC (Kiesling et al. 2019; Kurniawan, Kiesling, Winkler, et al. 2024), ditambah PROV-O (Lebo et al. 2013). Prefiks `attack:` merujuk namespace `http://w3id.org/sepses/vocab/ref/attack#`; berkas RML ICS-SEC dan prototipe memakai nama prefiks `cat:` untuk namespace yang sama. Ekstensi (`ext:`) hanya dibuat untuk konsep yang belum ada pada kosakata tersebut, yaitu laporan beserta `object_refs`, sektor dan negara sasaran, atribut validitas waktu, produk terdampak dan penilaian *exposure*, serta status KEV. Pembuat laporan memakai PROV-O. Setiap istilah baru harus dapat ditelusuri ke minimal satu CQ (tabel *trace term*→CQ); istilah

tanpa CQ tidak dimasukkan. Ontologi divalidasi dengan OOPS! (Poveda-Villalón et al. 2014), reasoner untuk konsistensi, dan SHACL (Knublauch and Kontokostas 2017) dengan *fixture* positif dan negatif.

Gambar 4.5 memperlihatkan skema (T-box) yang diturunkan dari CQ1–CQ8. Skema dibedakan dari instans (A-box): *IntrusionSet* adalah kelas, sedangkan Lazarus atau RomCom adalah instansnya. Relasi pada lapisan ancaman tidak dirancang dari asumsi, tetapi diambil dari `relationship_type` yang benar-benar teramati pada data D1:

- *indicator* `indicates` *malware*/aktor/teknik;
- aktor `uses` *malware*/teknik, dan *malware* `uses` teknik;
- aktor, *malware*, dan teknik `targets` CVE;
- aktor dan *malware* `targets` sektor/lokasi.

Data tidak memuat relasi langsung antara sektor dan lokasi, sehingga relasi itu tidak dimodelkan. Tabel 4.4 menelusuri setiap kelas ke asal kosakatanya dan CQ yang membutuhkannya. Kelas yang tidak dibutuhkan CQ mana pun tidak dimasukkan.



Biru: kelas STIX yang dipetakan ke kosakata `attack:` SEPSES/ICS-SEC. Hijau: kosakata kerentanan SEPSES. Jingga: *provenance* (laporan, pembuat, waktu). Kuning putus-putus: istilah perluasan (`ext:`, namespace sementara). Label relasi pada lapisan ancaman adalah `relationship_type` STIX yang teramati pada data; dalam pola SEPSES, relasi direpresentasikan sebagai *resource* dengan `attack:relationshipType`. *Observable* (file, URL, domain) tidak dimodelkan. Nama kelas sama dengan berkas T-box prototipe v0.1; Indicator dirancang di sini tetapi baru dipetakan pada v0.2.

Gambar 4.5. Skema ontologi aplikasi (T-box): kelas dan relasi yang dibutuhkan CQ1–CQ8 dan CQ3b

4.4.2 Perluasan Pemetaan `cat-json.rml`

SEPSES sudah memetakan STIX (data MITRE ATT&CK) ke RDF melalui `cat-json.rml` (SEPSES Team 2024). Setiap objek STIX menjadi `attack:{type}` dengan IRI berbasis `id` STIX, sedangkan relasi menjadi resource dengan `attack:relationshipType`, `attack:hasSourceRef`, dan `attack:hasTargetRef`. Pemetaan itu belum mencakup atribut CTI operasional

Tabel 4.4. Penelusuran kelas ontologi ke asal kosakata dan CQ (*trace* istilah→CQ)

Kelas	**Asal kosakata**	**Alasan**	**CQ**
Aset, Produk terdampak, Penilaian *exposure*	Perluasan (`ext:Asset`, `ext:AffectedProduct`, `ext:ExposureAssessment`); CPE SEPSES bila tersedia	Mencocokkan produk/versi aset dengan CVE, termasuk CVE tanpa CPE eksplisit	CQ1, CQ8
CVE, CVSS, CWE, CAPEC	SEPSES (`cve:`, `cvss:`, `cwe:`, `capec:`)	Konteks kerentanan	CQ1–CQ3, CQ7
IntrusionSet, Malware, AttackPattern	STIX 2.1 → `attack:` (ICS-SEC)	Konteks ancaman yang terkait CVE	CQ3, CQ4
Indicator	STIX 2.1 → `attack:`	Indikator yang masih berlaku bagi aktor/*malware* (`valid_until`, `revoked`)	CQ3b, CQ5
Sektor, Negara	STIX 2.1 (`identity` *class*, `location`) → `ext:Sector`, `ext:Country`	Relevansi bagi organisasi	CQ4, CQ8
Laporan	STIX 2.1 (`report`) → `ext:Report` (belum ada di ICS-SEC)	Waktu terbit dan isi laporan sebagai bukti	CQ4–CQ6
Agen	PROV-O (`prov:Agent`)	Pembuat laporan atau konektor	CQ6
Status KEV	Perluasan (`ext:`)	Tanggal masuk KEV per t	CQ7, CQ8

karena ATT&CK adalah data referensi statis. Penelitian ini menambah *triples map* untuk laporan dan `object_refs`, identity (sektor), location, vulnerability, dan *indicator*, serta atribut waktu dan *provenance*: `published`, `created_by_ref`, `valid_from`, `valid_until`, `revoked`, dan `confidence`. *Observable* (file, URL, domain, *hostname*) tidak dipetakan karena pola IOC sudah tersimpan pada *indicator* dan tidak ada CQ yang membutuhkannya. Atribut `created`/`modified` pada relasi STIX juga tidak dipakai sebagai waktu bukti, karena pada data D1 keduanya adalah waktu impor ke OpenCTI (Subbab 4.9.2). Transformasi dijalankan pada seluruh 986 laporan. CVE 2025–2026 yang belum ada di seed SEPSES dikonversi dari CVE List v5 ke kosakata SEPSES dengan memakai ulang transformer dari pekerjaan pendahuluan.

[Diskusi: Implementasi: memperluas *pipeline* Java/RML SEPSES agar hasil dapat masuk ekosistem SEPSES, atau Python (lanjutan pekerjaan pendahuluan) dengan IRI dan kosakata yang identik?]

4.4.3 Entity Linking

Entity linking menautkan objek STIX ke IRI yang sudah ada sehingga konteks ancaman dan lapisan kerentanan berada dalam satu graf.

- `vulnerability` STIX → IRI CVE SEPSES melalui ID CVE ternormalisasi;
- `identity` berjenis *class* → kosakata sektor;
- `location` → kode ISO 3166;
- `malware`, `intrusion-set`, dan `attack-pattern` → IRI `attack:` SEPSES melalui `external_id` ATT&CK (Txxxx/Gxxxx/Sxxxx) bila *external reference* tersedia.

Kebutuhan ini nyata pada data. Aktor Lazarus, misalnya, muncul dengan lima nama berbeda ("Lazarus", "Lazarus Group", "Lazarus Group (Famous Chollima division)", "Lazarus Group, Kimsuky", dan "APT-C-26 (Lazarus)"), tanpa `external_id` ATT&CK maupun daftar alias. Tanpa penautan, kueri tentang Lazarus akan kehilangan sebagian buktinya. Kegagalan *linking* dicatat dalam laporan *linking*, bukan dibuang, agar dapat dianalisis pada tahap 11.

4.4.4 *Provenance* per Laporan

Setiap pernyataan konteks ancaman harus dapat ditelusuri ke laporan, pembuat, waktu, dan referensinya (CQ6, U3). Dasar teorinya dibahas pada Subbab 3.5. Agen dan waktu dicatat dengan PROV-O, misalnya `prov:wasAttributedTo` dan `prov:generatedAtTime` (Lebo et al. 2013). Untuk mengikat pernyataan ke laporannya tersedia dua kandidat pola: (a) RDF-star (Hartig et al. 2021), selaras dengan pola ICS-SEC yang menganotasi *quoted triple* dengan `attack:hasReference` (Kurniawan, Kiesling, Winkler, et al. 2024); atau (b) *named graph* per laporan (Cyganiak et al. 2014). Kedua pola dapat dievaluasi dengan U3. Kriteria pemilihannya adalah kemudahan kueri per waktu t dan dukungan triplestore.

[Diskusi: RDF-star (selaras ICS-SEC) atau named graph per laporan? Apakah hasil diharapkan menjadi modul resmi SEPSES?]

4.5 Competency Questions

CQ diturunkan ulang dari CQ pekerjaan pendahuluan dan dipilih sesuai masalah penelitian ini. Tabel 4.5 memuat delapan CQ utama dan satu CQ turunan (CQ3b) beserta jalur relasi pada skema (Gambar 4.5) yang dipakai untuk menjawabnya dan ukuran yang mengujinya. CQ3b menjawab langkah lanjutan analis sesudah CQ3, yaitu indikator apa yang perlu dicari, dan sejalan dengan contoh CQ pembimbing pada pertemuan 1 ("*vulnerability* untuk indikator X"). CQ3b dilaporkan secara deskriptif dan tidak masuk F1 utama. Evaluasi kualitas atau kedaluwarsa *indicator*, kualitas bukti, *ranking*, *fidelity*, dan *robustness* berada di luar lingkup. Setiap CQ diwujudkan sebagai templat SPARQL (Harris and Seaborne 2013); CQ3b, CQ4, CQ5, CQ7, dan CQ8 menerima parameter t (dan W untuk CQ4, CQ5, dan CQ8).

Tabel 4.5. *Competency question* (CQ1–CQ8 dan CQ3b), jalur relasi, dan ukuran terkait

ID	Pertanyaan	Jalur relasi	Ukuran
CQ1	CVE apa yang memengaruhi aset (produk/versi), dengan status TRUE/FALSE/UNKNOWN dan dasar pencocokannya?	Aset ← Penilaian *exposure* → CVE; CVE $\xrightarrow{\text{hasAffectedProduct}}$ produk terdampak (rentang versi atau CPE)	U1, U4
CQ2	Berapa CVSS, CWE, dan CAPEC setiap CVE tersebut?	CVE → CVSS; CVE → CWE → CAPEC	U1
CQ3	Aktor, *malware*, atau teknik mana yang dinyatakan terkait CVE tersebut?	{aktor, *malware*, teknik} $\xrightarrow{\text{targets}}$ CVE	U1, U4
CQ3b	Indikator mana yang masih berlaku pada waktu t untuk aktor atau *malware* pada jawaban CQ3?	*Indicator* $\xrightarrow{\text{indicates}}$ {aktor, *malware*} $\xrightarrow{\text{targets}}$ CVE; filter `valid_from` $\leq t <$ `valid_until`, tidak `revoked`	deskriptif
CQ4	Apakah ada laporan sah-waktu yang mengaitkan CVE tersebut dengan sektor atau wilayah organisasi?	Laporan $\xrightarrow{\text{memuat}}$ (… targets CVE) *dan* Laporan $\xrightarrow{\text{memuat}}$ sektor/lokasi	U1, U2
CQ5	Per waktu keputusan t, konteks ancaman mana yang masih berlaku (sudah terbit, belum dicabut/kedaluwarsa, dan berada dalam jendela kebaruan W)?	Jalur CQ3 + filter `published`, `revoked`, `valid_until`, W pada laporan pendukung	U2
CQ6	Laporan, pembuat, waktu, dan referensi apa yang mendukung setiap pernyataan konteks?	Pernyataan $\xleftarrow{\text{memuat}}$ Laporan $\xrightarrow{\text{wasAttributedTo}}$ Agen; `published`	U3
CQ7	Apakah CVE berstatus KEV per waktu t, dan sejak kapan?	CVE → `ext:kevDateAdded` $\leq t$	U1, U2
CQ8	Apa tier prioritas pasangan aset–CVE per waktu t, dan jalur bukti mana yang menjadi dasarnya?	Gabungan CQ1, CQ7, dan CQ4 (lihat Subbab 4.6.3)	U3, U5

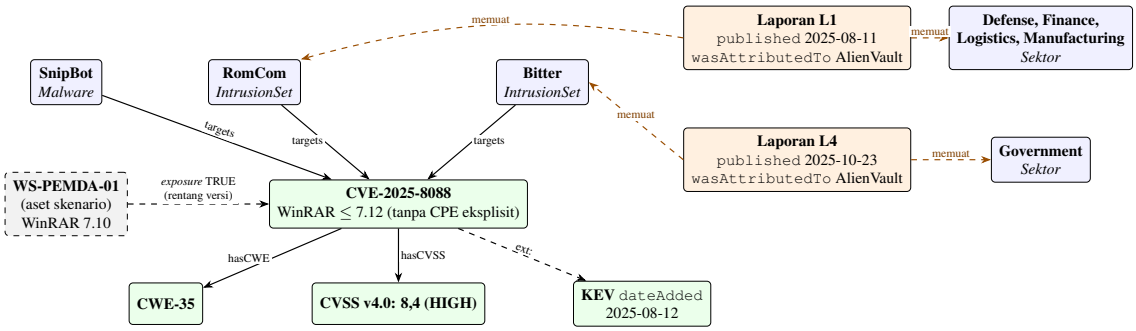
4.5.1 Contoh Terapan: CVE-2025-8088

Agar CQ tidak abstrak, setiap CQ diuji pada contoh nyata dari data, yaitu CVE-2025-8088 pada WinRAR (Gambar 4.6). Satu-satunya bagian yang bukan data nyata adalah aset skenario WS-PEMDA-01, sebuah komputer kerja di instansi pemerintah yang menjalankan WinRAR 7.10. Fakta dari data adalah sebagai berikut:

- rekaman CVE List v5 terbit 8 Agustus 2025, dengan *affected* WinRAR $\leq$ 7.12 dan tanpa CPE eksplisit;
- CVE ini masuk KEV pada 12 Agustus 2025 dan tercatat dipakai dalam kampanye *ransomware*;
- lima laporan AlienVault menyebut CVE ini, yaitu pada 11 dan 25 Agustus, 15 September, serta 23 dan 28 Oktober 2025;
- hanya laporan 23 Oktober 2025 (aktor Bitter) yang juga memuat sektor Government.

Tabel 4.6 memperlihatkan jawaban yang diharapkan untuk dua waktu keputusan.

Contoh ini juga menunjukkan mengapa aspek waktu dan *provenance* diturunkan



Semua instans diambil dari data D1, CVE List v5, dan KEV, kecuali aset WS-PEMDA-01 (skenario). Laporan lain yang menyebut CVE ini (25 Agustus, 15 September, dan 28 Oktober 2025) tidak digambar agar ringkas. Relevansi sektor Government hanya didukung oleh laporan L4, sehingga *belum* sah-waktu pada t = 30 September 2025 dan sah-waktu pada t = 31 Desember 2025.

Gambar 4.6. Contoh instans (A-box) untuk CVE-2025-8088 beserta *provenance* per laporan

Tabel 4.6. Jawaban CQ yang diharapkan untuk WS-PEMDA-01 dan CVE-2025-8088 (W = 90 hari)

CQ	**t = 30 September 2025**	**t = 31 Desember 2025**
CQ1	TRUE melalui rentang versi ($7.10 \leq 7.12$), bukan CPE	sama
CQ2	CVSS v4.0 8,4 (HIGH); CWE-35	sama
CQ3	RomCom, SnipBot, Mythic, RustyClaw, dan teknik terkait (laporan 11 Agustus–15 September)	ditambah Bitter dan Earth Estries (laporan 23 dan 28 Oktober)
CQ4 (sektor Government)	**Tidak**: laporan yang memuat Government belum terbit	**Ya**: laporan 23 Oktober, berumur 69 hari ($\leq W$)
CQ5	Hanya laporan $\leq$ 30 September; laporan 11 Agustus masih dalam W (50 hari)	Laporan Agustus dan 15 September sudah usang ($> W$); laporan 23 dan 28 Oktober sah-waktu
CQ6	Setiap pernyataan $\rightarrow$ laporan, `published`, AlienVault	sama
CQ7	Ya, KEV sejak 12 Agustus 2025	sama
CQ8	Tier ditentukan dengan relevansi = tidak	Tier ditentukan dengan relevansi = ya
Integrasi naif (B1)	Menjawab CQ3–CQ4 dengan seluruh laporan tanpa memandang t. Pada t = 30 September, B1 menyatakan relevansi Government *ya*, padahal buktinya baru terbit 23 Oktober (bocor dari masa depan).	

dari kebutuhan CQ, bukan ditambahkan sebagai fitur. Jawaban CQ4 dan CQ8 untuk aset dan CVE yang sama berubah menurut waktu keputusan, dan perubahan itu hanya dapat dijelaskan bila setiap pernyataan membawa laporan dan tanggal terbitnya.

4.6 Rancangan Penalaran

Penalaran bersifat deterministik dan berbasis aturan; tidak ada model terlatih. Ada tiga komponen yang dijalankan secara berurutan.

4.6.1 *Exposure* Aset

Profil aset skenario (produk/versi) dicocokkan dengan CVE melalui CPE dan *affected/version-range* pada record CVE, dengan memakai ulang reasoner *exposure* dari pekerjaan pendahuluan. Statusnya adalah TRUE (versi terbukti terdampak), FALSE (versi terbukti tidak terdampak), atau UNKNOWN (tidak dapat dipastikan), mengikuti logika tiga nilai pada Subbab 3.8. Status UNKNOWN dipertahankan secara eksplisit karena hanya 7,71% record CVE List v5 memiliki CPE eksplisit, sehingga pencocokan sering tidak dapat dipastikan.

4.6.2 Keabsahan Waktu Bukti (*Admissibility*)

Sebuah pernyataan konteks ancaman e dinyatakan sah-waktu (*admissible*) pada waktu keputusan t dengan jendela kebaruan W bila memenuhi Persamaan (3-4) pada Subbab 3.6. Secara operasional, ada empat syarat:

(i) sedikitnya satu laporan pendukungnya sudah terbit (`published` $\leq t$);
(ii) objeknya tidak berstatus `revoked` per t (hanya bila riwayat versi tersedia; lihat K16);
(iii) untuk *indicator*, `valid_until` $> t$;
(iv) laporan pendukung terbarunya terbit tidak lebih dari W hari sebelum t.

Aturan ini diwujudkan sebagai templat SPARQL parametrik yang menerima t dan W. Pada integrasi naif (B1), keempat syarat tersebut tidak diperiksa. Dampak kelalaian ini sudah terlihat pada data pendahuluan (Tabel 1.1), dan besarannya diukur secara formal oleh U2.

4.6.3 Tier Prioritas Transparan

Tier prioritas pasangan aset–CVE ditentukan dengan tabel keputusan bergaya SSVC (Spring et al. 2019), bukan dengan skor terlatih (dasar teorinya pada Subbab 3.9). Pasangan berstatus FALSE tidak diberi tier karena asetnya terbukti tidak terdampak, sehingga tidak memerlukan tindakan. Ada tiga titik keputusan:

1. *Exposure*: TRUE atau UNKNOWN (pasangan FALSE tidak diberi tier);
2. Eksploitasi: CVE berstatus KEV per t (ya/tidak);
3. Relevansi ancaman: terdapat laporan sah-waktu yang memuat CVE tersebut *sekaligus* sektor (utama) atau wilayah (sekunder) organisasi dalam jendela W (ya/tidak).

Relevansi didefinisikan per laporan, bukan melalui penelusuran transitif aktor/*malware*→`targets`→sektor di seluruh graf. Alasannya, aktor dan *malware* umumnya menyasar banyak sektor sekaligus. Dengan penelusuran transitif, 58,0% dari 352 CVE tertaut ke sektor Government. Dengan definisi per laporan, angkanya 39,2%, dan untuk Education 11,6% (dibanding 32,7% secara transitif). Definisi per laporan lebih

membedakan dan sejalan dengan prinsip *provenance* per laporan. Setiap tier disertai jalur bukti yang dapat ditelusuri (CQ8). Tabel dibekukan sebelum evaluasi. Tabel 4.7 memberi contoh baris; isi dan nama tier masih berupa *usulan*.

Tabel 4.7. Contoh tabel keputusan tier (*usulan*, belum dibekukan)

Exposure	KEV per t	Relevansi dalam W	Tier (usulan)
TRUE	ya	ya	*Act* (tindak segera)
TRUE	ya	tidak	*Attend*
TRUE	tidak	ya	*Attend*
TRUE	tidak	tidak	*Track*
UNKNOWN	ya	ya	*Attend* + verifikasi versi
UNKNOWN	tidak	tidak	*Track* + verifikasi versi

[Diskusi: Jumlah tier, label, dan pemetaan baris (termasuk kombinasi UNKNOWN yang belum tercantum) perlu disepakati sebelum pembekuan.]

4.7 Desain Eksperimen

4.7.1 Skenario Pembanding

Eksperimen membandingkan empat skenario pada data dan *test set* yang sama (Tabel 4.8). B0 berperan sebagai *baseline* tanpa CTI, B1 sebagai *baseline* integrasi tanpa *provenance* dan waktu, Usulan sebagai metode yang diajukan, dan *ablation* sebagai uji tekanan terhadap komponen. Uji tekanan tambahan diperoleh dari variasi titik waktu t dan jendela W, karena kondisi "bukti dari masa depan" dan "bukti usang" paling ekstrem terjadi pada t awal dan W pendek.

4.7.2 Titik Waktu dan Jendela Kebaruan

Setiap skenario dijalankan pada tiga titik waktu keputusan t, yaitu 30 Juni 2025, 30 September 2025, dan 31 Desember 2025. Jendela kebaruan utama adalah $W = 180$ hari, dan $W = 90$ hari dipakai sebagai analisis sensitivitas. Kedua nilai W ditetapkan di muka dan tidak disetel menggunakan *test set* **[Diskusi: apakah W = 180/90 hari sesuai praktik analis?]**.

4.7.3 *Gold Standard*

Kerangka sampel adalah 352 CVE yang disebut dalam CTI, ditambah pasangan aset–CVE dari profil skenario. Ukuran yang diusulkan adalah 60 CVE: 20 untuk *dev* dan 40 untuk *test*. Pengambilan sampel distratifikasi agar kasus sulit terwakili:

- ada vs tidak ada di seed SEPSES;
- disebut 1 laporan vs ≥ 2 laporan;

Tabel 4.8. Skenario eksperimen

Skenario	Deskripsi	Fungsi
B0 SEPSES-saja	Penilaian kerentanan ala Kiesling et al. (2019): aset→CPE→CVE + CVSS/CWE/CAPEC	Menunjukkan apa yang tidak terjawab tanpa CTI (U4)
B1 Integrasi naif	STIX dipetakan langsung ke RDF dalam satu *default graph*: tanpa *provenance* per laporan, tanpa filter waktu, *linking* CVE berbasis string nama	Mengisolasi dampak *provenance* dan waktu (U2, U3)
Usulan	Ontologi + *provenance* per laporan + PROV-O + *entity linking* + *admissibility* per waktu t	–
Ablation	(a) Usulan tanpa filter waktu; (b) Usulan tanpa *entity linking* ternormalisasi	Menunjukkan komponen yang menyebabkan perbedaan

- CVE terbitan $\leq$ 2024 vs 2025;
- ada vs tidak ada relasi sektor/wilayah.

Pembagian *dev*/*test* dilakukan secara acak dengan *seed* tetap. Daftar ID di-hash dan dicatat *sebelum pipeline* dievaluasi.

Gold answer CQ3–CQ7 diturunkan *langsung* dari JSON STIX mentah dan katalog KEV dengan pedoman anotasi tertulis, bukan dari keluaran *pipeline*. *Gold answer* CQ1–CQ2 diturunkan dari record CVE/NVD dan profil aset. Sebanyak 20% sampel dianotasi ulang oleh anotator kedua (pembimbing atau rekan). Reliabilitas dilaporkan dengan Cohen's κ (Cohen 1960) dengan target $\kappa \geq 0{,}80$; ketidaksepakatan diselesaikan dan dicatat **[Diskusi: siapa anotator kedua? apakah 60 CVE cukup?]**.

4.8 Validation, Testing, dan Evaluation

Ketiga tahap ini dipisahkan secara tegas (Tabel 4.9). Karena tidak ada model terlatih, *validation* di sini berarti pengembangan dan perbaikan pemetaan, aturan *linking*, serta templat per waktu t pada *dev set*.

Metrik dan kriteria keputusan ditunjukkan pada Tabel 4.10; dasar teorinya (P/R/F1, F1 makro, *bootstrap*, dan κ) dibahas pada Subbab 3.10. RQ dinyatakan terjawab positif bila kriteria U1, U2, dan U3 terpenuhi. Bila U1 tidak tercapai, hasil tetap dilaporkan apa adanya beserta analisis kesalahannya.

[Diskusi: Ambang F1 $\geq$ 0,90, 0% bukti tidak sah-waktu, dan 100% ketertelusuran adalah usulan; dibekukan bersama pembimbing sebelum test set dibuka.]

Pada U5, EPSS (Jacobs, Romanosky, Suciu, et al. 2023), CVSS (Forum of In-

Tabel 4.9. Pemisahan validation, testing, dan evaluation

Tahap	Data	Boleh mengubah metode?
Development/ validation	*Dev set* (20 CVE) + seluruh data untuk *debugging*	Ya: pemetaan, aturan *linking*, templat per waktu t
Testing	*Test set* (40 CVE), disegel	**Tidak.** Dijalankan satu kali sesudah ontologi, pemetaan, aturan, dan tabel tier dibekukan (tag rilis + hash)
Evaluation	Keluaran *testing*	Tidak; hanya menghitung metrik U1–U5, CI *bootstrap*, dan analisis kesalahan

Tabel 4.10. Metrik evaluasi dan kriteria keputusan (ambang = *usulan*)

Ukuran	Metrik	Pembanding	Kriteria (usulan)
U1 Kebenaran	Precision, recall, F1 per CQ; F1 makro; CI *bootstrap* 95% (*resampling* CVE)	B0, B1	F1 makro Usulan $\geq 0{,}90$ *dan* batas bawah CI $>$ F1 B1
U2 Waktu	% jawaban per waktu t yang memuat bukti tidak sah-waktu (bocor masa depan/usang/dicabut); % jawaban B1 yang berubah	B1	Usulan 0%; besaran B1 dilaporkan
U3 Ketertelusuran	% pernyataan konteks dengan jejak lengkap (laporan, pembuat, waktu, referensi); jumlah pelanggaran SHACL	B1	100%; 0 pelanggaran pada data valid; seluruh *fixture* negatif ditolak
U4 *Coverage*	Jumlah dan % CVE serta pasangan aset–CVE yang memiliki konteks ancaman	B0	Dilaporkan (tanpa ambang)
U5 Kegunaan	Studi kasus 2 profil; kuesioner Likert 1–5 (dapat dipahami, dapat ditindaklanjuti, dapat dipercaya) untuk 3–5 praktisi bila tersedia	CVSS/KEV/ EPSS (deskriptif)	Dilaporkan; bukan syarat RQ

cident Response and Security Teams 2019), dan KEV (Cybersecurity and Infrastructure Security Agency 2026) hanya dipakai sebagai pembanding deskriptif. Penelitian ini tidak mengklaim *ranking* yang lebih akurat daripada sumber-sumber tersebut.

4.9 Hasil Pendahuluan

Bagian ini memisahkan pekerjaan yang sudah dilakukan dari rencana. Seluruh hasil di bawah adalah *preliminary*: hasil tersebut menunjukkan kelayakan, bukan jawaban atas RQ.

4.9.1 Realitas Data OpenCTI

Analisis *read-only* atas ekspor OpenCTI (D1), SEPSES lokal, CVE List v5, dan KEV menghasilkan angka indikator yang telah disajikan pada Tabel 1.1. Sebagian temuan baru muncul saat prototipe KG dibangun (Subbab 4.9.2), lalu diukur ulang pada seluruh korpus. Tabel 4.11 tidak mengulang angka tersebut, tetapi menunjukkan bagaimana setiap temuan membentuk keputusan rancangan.

4.9.2 Prototipe KG v0.1 pada Sampel Kecil

Untuk memeriksa bahwa rancangan pada Subbab 4.4–4.6 dapat dijalankan, alur kerja pada Gambar 4.3 (tahap 4–6 dan 8a) dicoba pada sampel kecil. Sampel terdiri atas 7 laporan OpenCTI (11 Agustus–25 November 2025) yang menyebut CVE-2025-8088, CVE-2025-6218 (WinRAR), atau CVE-2025-64446 (FortiWeb), ditambah 5 aset skenario milik sebuah pemerintah daerah. Pemetaan ditulis dalam Python dengan `rdflib`. Hasilnya adalah KG berukuran 4.739 *triple* dalam 14 graf bernama: satu graf per laporan untuk *provenance*, ditambah graf entitas, metadata laporan, CVE (kosakata SEPSES), KEV, aset, dan hasil *exposure*. KG dimuat ke Apache Jena Fuseki (TDB2) dan lolos validasi SHACL tanpa *violation*. Ada 9 *warning* untuk CVE yang disebut laporan tetapi tidak punya rekaman CVE. Sesuai keputusan lingkup (K14), *indicator* belum dipetakan pada v0.1 dan baru ditambahkan pada v0.2. Tabel 4.12 merangkum CQ yang sudah dapat dijawab.

Sebagai contoh, kueri CQ3 sah-waktu hanya memakai relasi dari graf laporan yang tanggal terbitnya berada dalam jendela $[t - W, t]$:

```
GRAPH ?lap { ?r cat:hasTargetRef ?c ;
               cat:relationshipType "targets" ;
               cat:hasSourceRef ?x . }
GRAPH g:report-metadata { ?lap ext:published ?terbit . }
FILTER(?terbit <= ?t && ?terbit >= ?tMulai)
```

Konstruksi ini memunculkan tiga temuan yang tidak terlihat dari profil data saja:

1. atribut `created`/`modified` pada relasi STIX dari OpenCTI adalah waktu impor (Maret 2026), sehingga waktu bukti harus diambil dari tanggal terbit laporan. Pada seluruh korpus, hal ini berlaku untuk 100% relasi;
2. 51 relasi dalam sampel dirujuk oleh lebih dari satu laporan (pada seluruh korpus: 11,5% relasi "X `targets` CVE"), sehingga *provenance* perlu dicatat per laporan, bukan per relasi;
3. nama vendor berbeda antarsumber ("win.rar GmbH" dan "RARLAB"), dan varian nama aktor ("RomCom" dan "RomCom, Paper Werewolf") belum disatukan; keduanya menjadi masukan *entity linking*.

Prototipe ini memakai graf bernama dan Python karena paling cepat dicoba. Pilihan tersebut belum final dan tetap menjadi bahan keputusan K3 dan K4 (Lampiran A).

4.9.3 Artefak Pekerjaan Pendahuluan

Pekerjaan pendahuluan sebelumnya menghasilkan artefak yang akan dipakai ulang, dengan status sebagaimana adanya:

- arsip ontologi v1 (SEPSES–CTI, 10 modul) beserta SHACL; modul ini terlalu luas sehingga tidak dilanjutkan apa adanya. Ontologi aplikasi dibangun ulang dari CQ sebagai deret v0.x, dimulai dari T-box prototipe v0.1 (Subbab 4.9.2); bagian arsip v1 yang cocok dirujuk bila diperlukan;
- transformer STIX→RDF dan CVE List v5→RDF yang baru diuji pada subset (17 laporan dan 12 CVE), belum pada skala penuh;
- reasoner *exposure/version-range* yang baru diuji pada *fixture* sintetis 14 aset;
- profil data AlienVault STIX, CVE List v5, dan SEPSES.

Pilot *ranking* dan *robustness* dari pekerjaan pendahuluan *tidak* dilanjutkan karena *holdout*-nya sudah terpakai; pilot itu hanya dirujuk sebagai pengalaman metodologis. Pemetaan literatur juga baru berada pada tahap awal: pencarian Scopus dan IEEE Xplore sudah dijalankan, dan bersama korpus lama serta pencarian terbuka terkumpul 410 rekaman (354 unik sesudah deduplikasi). *Screening* formal (Kitchenham and Charters 2007; Page et al. 2021) belum dilakukan dan dijadwalkan sesudah bimbingan.

4.10 Ancaman Validitas dan Etika

Tabel 4.13 merangkum ancaman validitas utama dan mitigasinya.

Dari sisi etika, data CTI yang dipakai berasal dari *feed* publik dan tidak memuat data organisasi nyata; profil aset bersifat skenario. Kuesioner praktisi pada U5 bersifat anonim, memakai *informed consent*, dan tidak mengumpulkan data organisasi responden. Prosedur etik fakultas diikuti bila disyaratkan **[Diskusi: perlukah persetujuan etik formal untuk kuesioner U5?]**. Lisensi setiap sumber data diverifikasi sebelum artefak

dipublikasikan.

4.11 Jadwal Penelitian

Kemajuan penelitian dilaporkan secara berkala kepada pembimbing melalui grup komunikasi bimbingan. Setiap laporan merujuk ke repositori GitHub penelitian yang memuat data mentah atau sampelnya, *input*, *output*, pemetaan, kueri CQ, dan hasil uji, sehingga hasil dapat diperiksa dan dijalankan ulang.

Tabel 4.14 menunjukkan rencana waktu pelaksanaan tesis dalam minggu relatif sesudah sidang proposal. Beberapa tahap berjalan tumpang tindih; *testing* pada minggu ke-12 hanya dapat dimulai sesudah pembekuan pada minggu ke-11.

Tabel 4.11. Temuan pendahuluan dan implikasinya pada rancangan

Temuan	**Keputusan rancangan**
Konteks ancaman tersedia luas: aktor 77%, *malware* 94%, teknik 93% dari 352 CVE; 62 kelas sektor sasaran	CQ3–CQ4 dapat dijawab; sektor menjadi dimensi relevansi utama
Hanya 2 identitas pembuat, dan 985 dari 986 laporan dibuat oleh konektor AlienVault	*Provenance* dicatat per laporan, bukan hanya per pembuat
45,8% asosiasi bocor dari masa depan dan 51,4% usang pada titik waktu yang diuji	Penalaran *admissibility* per waktu t; diukur dengan U2
204/352 CVE ada di KEV, tetapi laporan CTI umumnya terbit sesudah `dateAdded`; label "masuk KEV sesudah t" hanya 0–8 kasus positif	Prediksi eksploitasi tidak dijadikan tujuan; KEV dipakai sebagai dimensi tier per t
94% *indicator* kedaluwarsa dan 18.906 dicabut	Syarat `valid_until` dan `revoked` masuk aturan *admissibility*; *indicator* dipakai pada CQ3b, tetapi kualitas IOC tidak dievaluasi
Dari 352 CVE yang disebut CTI, 271 (77,0%) tercakup sumber lokal: 142 oleh CVE List v5 (semua CVE 2025), 95 oleh *seed* SEPSES 2021–2024, dan 34 oleh *dump* SEPSES 2019. Sebanyak 81 belum tercakup, terutama CVE 2024 (57) dan 2020 (17)	Lapisan CVE List v5 dalam kosakata SEPSES; celah 2020 dan 2024 menjadi bagian keputusan data (K5, DATA-01)
Seluruh 456.585 relasi STIX bertanggal `created` Maret 2026 (waktu impor), sedangkan `published` laporan tersebar Februari–Desember 2025	Waktu bukti diambil dari tanggal terbit laporan, bukan dari atribut waktu relasi
11,5% relasi "X `targets` CVE" dirujuk lebih dari satu laporan; selisih laporan pertama dan terakhir median 33 hari (p90 142 hari)	*Provenance* dicatat per laporan agar waktu bukti tidak hilang saat relasi yang sama dinyatakan ulang (K3)
985/986 laporan dibuat konektor AlienVault, tetapi 98,4% memuat URL penerbit asli dari 192 domain berbeda	*Provenance* dua tingkat: agregator dan penerbit asli (K15)
Relevansi sektor secara transitif terlalu luas (Government 58,0% CVE); per laporan lebih tajam (39,2%)	Relevansi didefinisikan per laporan (CQ4, tier)
Tidak ada satu pun dari 355 aktor dan 1.053 *malware* yang memiliki ID ATT&CK; 10 nama aktor adalah gabungan beberapa aktor (misalnya "RomCom, Paper Werewolf");	*Entity linking* aktor dan laporan kegagalan *linking*
Lazarus muncul dengan lima nama	
Hanya 7,71% rekaman CVE List v5 memiliki CPE eksplisit; pada CVE	Status UNKNOWN pada *exposure*; pencocokan juga memakai rentang versi

Tabel 4.12. Status CQ pada prototipe KG v0.1

CQ	Status	Hasil dan catatan
CQ1	Terjawab	8 pasangan aset–CVE: 4 TRUE, 1 FALSE, 3 UNKNOWN, masing-masing dengan dasar pencocokan
CQ2	Sebagian	CVSS dan CWE tersedia untuk 3 CVE contoh. SEPSES belum memiliki kelas CVSS v4.0, padahal CVE-2025-8088 hanya memiliki CVSS v4.0. Sebanyak 9 dari 23 CVE dalam sampel (terbit sebelum 2025) belum dimuat karena *seed* SEPSES lokal belum dipasang pada prototipe
CQ3	Terjawab	Tanpa waktu: 13 aktor/*malware*. Pada t = 30 September 2025 (W = 180): 7. Artinya 6 dari 13 berasal dari laporan yang terbit sesudah t
CQ4	Terjawab	Sektor Government untuk CVE-2025-8088 hanya didukung laporan 23 Oktober 2025, sehingga belum sah pada t = 30 September
CQ5	Terjawab	Setiap laporan diberi label berlaku, belum terbit, atau usang per skenario t dan W
CQ6	Sebagian	Setiap pernyataan dapat ditelusuri ke laporan, tanggal, pembuat, dan URL. Pembuat selalu konektor AlienVault, sedangkan penerbit asli hanya tersimpan di URL
CQ7	Terjawab	Pada t = 30 September 2025 hanya CVE-2025-8088 yang berstatus KEV; CVE-2025-6218 baru masuk KEV pada 9 Desember 2025
CQ8	Belum	Dikerjakan pada iterasi berikutnya

Tabel 4.13. Ancaman validitas dan mitigasi

Ancaman	Mitigasi
Gold standard dibuat peneliti sendiri	Pedoman tertulis; anotasi dari data mentah; anotator kedua 20%; Cohen's κ
Satu *feed* CTI (AlienVault) dengan 2 identitas pembuat	Dinyatakan sebagai batasan; opsi penambahan sumber pada DATA-01
Rekonstruksi waktu dari satu *snapshot*	Memakai `published` dan `created`; tidak mengklaim histori revisi objek
Profil aset skenario	Disebut skenario; produk dari CVE nyata; asumsi didokumentasikan; dibekukan sebelum anotasi
Sampel kecil (60 CVE)	CI *bootstrap*; stratifikasi; tanpa klaim generalisasi ke populasi
Kebocoran *test set*	Hash daftar *test* sebelum evaluasi; eksekusi satu kali; log *run*
Endpoint SEPSES tidak merespons per 9 Oktober 2026	Memakai seed/dump lokal yang dipin; status endpoint ditanyakan ke pembimbing

Tabel 4.14. Jadwal penelitian (minggu relatif sesudah sidang proposal)

Minggu	Kegiatan	Tahap
1–2	Revisi dari sidang; pembekuan CQ, ukuran, dan data (DATA-01)	2–3
3–5	Ontologi v0.2 dan SHACL	4
4–8	Transformasi penuh, *entity linking*, Fuseki	5
7–9	Penalaran: *exposure*, per waktu t, tier	6
8–10	*Gold standard* dan anotator kedua	7
10–11	*Development* (*dev set*), lalu pembekuan	8
12	*Testing* satu kali	9
13–14	Evaluasi, analisis kesalahan, studi kasus/kuesioner	10–11
13–20	Penulisan tesis; rilis artefak; draf makalah (*resource/method paper*)	–

DAFTAR PUSTAKA

Albanese, M., I. Iganibo, and O. Adebiyi (2023). "A framework for designing vulnerability metrics". In: *Computers & Security* 132, p. 103382. DOI: 10.1016/j.cose.2023.103382. URL: http://dx.doi.org/10.1016/j.cose.2023.103382.

Allegretta, M., G. Siracusano, R. Gonzalez, and M. Gramaglia (2023). "Are crowdsourced CTI datasets ready for supporting anti-cybercrime intelligence?" In: *Computer Networks* 234, p. 109920. DOI: 10.1016/j.comnet.2023.109920. URL: http://dx.doi.org/10.1016/j.comnet.2023.109920.

Arp, D., E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck (2022). "Dos and Don'ts of Machine Learning in Computer Security". In: *31st USENIX Security Symposium (USENIX Security 22)*. USENIX Association. URL: https://www.usenix.org/conference/usenixsecurity22/presentation/arp.

Bouwman, X., H. Griffioen, J. Egbers, C. Doerr, B. Klievink, and M. van Eeten (2020). "A Different Cup of TI? The Added Value of Commercial Threat Intelligence". In: *29th USENIX Security Symposium (USENIX Security 20)*. USENIX Association. URL: https://www.usenix.org/conference/usenixsecurity20/presentation/bouwman.

Bratsas, C., E. K. Anastasiadis, A. K. Angelidis, L. Ioannidis, R. Kotsakis, and S. Ougiaroglou (2024). "Knowledge Graphs and Semantic Web Tools in Cyber Threat Intelligence: A Systematic Literature Review". In: *Journal of Cybersecurity and Privacy* 4.3, pp. 518–545. DOI: 10.3390/jcp4030025. URL: http://dx.doi.org/10.3390/jcp4030025.

Briliyant, O. C., N. P. Tirsa, and M. A. Hasditama (2021). "Towards an Automated Dissemination Process of Cyber Threat Intelligence Data using STIX". In: *2021 6th International Workshop on Big Data and Information Security (IWBIS)*. IEEE, pp. 109–114. DOI: 10.1109/iwbis53353.2021.9631850. URL: http://dx.doi.org/10.1109/iwbis53353.2021.9631850.

Chen, S.-S., R.-H. Hwang, A. Ali, Y.-D. Lin, Y.-C. Wei, and T.-W. Pai (2024). "Improving quality of indicators of compromise using STIX graphs". In: *Computers & Security* 144, p. 103972. DOI: 10.1016/j.cose.2024.103972. URL: http://dx.doi.org/10.1016/j.cose.2024.103972.

Cohen, J. (1960). "A Coefficient of Agreement for Nominal Scales". In: *Educational and Psychological Measurement* 20.1, pp. 37–46. DOI: 10.1177/001316446002000104. URL: http://dx.doi.org/10.1177/001316446002000104.

Cybersecurity and Infrastructure Security Agency (2021). *Binding Operational Directive 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities*. URL:

https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities.

Cybersecurity and Infrastructure Security Agency (2026). *Known Exploited Vulnerabilities Catalog*. Versi katalog 2026.08.27 yang dipakai dalam penelitian ini. URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog.

Cyganiak, R., D. Wood, and M. Lanthaler (2014). *RDF 1.1 Concepts and Abstract Syntax*. W3C Recommendation, 25 February 2014. World Wide Web Consortium. URL: https://www.w3.org/TR/rdf11-concepts/.

Dong, X. L., L. Berti-Equille, and D. Srivastava (2009). "Integrating conflicting data: the role of source dependence". In: *Proceedings of the VLDB Endowment* 2.1, pp. 550–561. DOI: 10.14778/1687627.1687690. URL: http://dx.doi.org/10.14778/1687627.1687690.

Forum of Incident Response and Security Teams (2019). *Common Vulnerability Scoring System v3.1: Specification Document*. URL: https://www.first.org/cvss/v3.1/specification-document.

Griffioen, H., T. Booij, and C. Doerr (2020). "Quality Evaluation of Cyber Threat Intelligence Feeds". In: *Applied Cryptography and Network Security*. Springer International Publishing, pp. 277–296. DOI: 10.1007/978-3-030-57878-7_14. URL: http://dx.doi.org/10.1007/978-3-030-57878-7_14.

Harris, S. and A. Seaborne (2013). *SPARQL 1.1 Query Language*. W3C Recommendation, 21 March 2013. World Wide Web Consortium. URL: https://www.w3.org/TR/sparql11-query/.

Hartig, O., P.-A. Champin, G. Kellogg, and A. Seaborne (2021). *RDF-star and SPARQL-star*. Final Community Group Report, 17 December 2021. W3C RDF-DEV Community Group. URL: https://w3c.github.io/rdf-star/cg-spec/2021-12-17.html.

Hemberg, E., M. J. Turner, N. Rutar, and U.-M. O'reilly (2024). "Enhancements to Threat, Vulnerability, and Mitigation Knowledge for Cyber Analytics, Hunting, and Simulations". In: *Digital Threats: Research and Practice* 5.1, pp. 1–33. DOI: 10.1145/3615668. URL: http://dx.doi.org/10.1145/3615668.

Jacobs, J., S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman (2021). "Exploit Prediction Scoring System (EPSS)". In: *Digital Threats: Research and Practice* 2.3, pp. 1–17. DOI: 10.1145/3436242. URL: http://dx.doi.org/10.1145/3436242.

Jacobs, J., S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi (2023). "Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights". In: *2023 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. IEEE, pp. 194–206. DOI: 10.1109/eurospw59978.2023.00027. URL: http://dx.doi.org/10.1109/eurospw59978.2023.00027.

Jordan, B., R. Piazza, and T. Darley (2021). *STIX Version 2.1*. OASIS Standard, 10 June 2021. OASIS. URL: https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html.

Jung, B., Y. Li, and T. Bechor (2022). “CAVP: A context-aware vulnerability prioritization model”. In: *Computers & Security* 116, p. 102639. DOI: 10.1016/j.cose.2022.102639. URL: http://dx.doi.org/10.1016/j.cose.2022.102639.

Kiesling, E., A. Ekelhart, K. Kurniawan, and F. Ekaputra (2019). “The SEPSES Knowledge Graph: An Integrated Resource for Cybersecurity”. In: *The Semantic Web – ISWC 2019*. Springer International Publishing, pp. 198–214. DOI: 10.1007/978-3-030-30796-7_13. URL: http://dx.doi.org/10.1007/978-3-030-30796-7_13.

Kitchenham, B. and S. Charters (2007). *Guidelines for Performing Systematic Literature Reviews in Software Engineering*. EBSE Technical Report EBSE-2007-01. Keele University and Durham University.

Knublauch, H. and D. Kontokostas (2017). *Shapes Constraint Language (SHACL)*. W3C Recommendation, 20 July 2017. World Wide Web Consortium. URL: https://www.w3.org/TR/shacl/.

Koscinski, V., M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli (2025). “Conflicting Scores, Confusing Signals: An Empirical Study of Vulnerability Scoring Systems”. In: *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*. CCS ’25. ACM, pp. 1904–1918. DOI: 10.1145/3719027.3765210. URL: http://dx.doi.org/10.1145/3719027.3765210.

Kurniawan, K., A. Ekelhart, and E. Kiesling (2021). “An ATT&CK-KG for Linking Cybersecurity Attacks to Adversary Tactics and Techniques”. In: *ISWC 2021 Posters, Demos and Industry Tracks*. Vol. 2980. CEUR Workshop Proceedings. URL: https://ceur-ws.org/Vol-2980/paper363.pdf.

Kurniawan, K., A. Ekelhart, E. Kiesling, G. Quirchmayr, and A. M. Tjoa (2022). “KRYSTAL: Knowledge graph-based framework for tactical attack discovery in audit data”. In: *Computers & Security* 121, p. 102828. DOI: 10.1016/j.cose.2022.102828. URL: http://dx.doi.org/10.1016/j.cose.2022.102828.

Kurniawan, K., A. Ekelhart, E. Kiesling, D. Winkler, G. Quirchmayr, and A. M. Tjoa (2022). “VloGraph: A Virtual Knowledge Graph Framework for Distributed Security Log Analysis”. In: *Machine Learning and Knowledge Extraction* 4.2, pp. 371–396. DOI: 10.3390/make4020016. URL: http://dx.doi.org/10.3390/make4020016.

Kurniawan, K., E. Kiesling, and A. Ekelhart (2024). *CyKG-RAG: Towards Knowledge-Graph Enhanced Retrieval Augmented Generation for Cybersecurity*. Tech. rep. RAGE-KG Workshop.

Kurniawan, K., E. Kiesling, D. Winkler, and A. Ekelhart (2024). “The ICS-SEC KG: An Integrated Cybersecurity Resource for Industrial Control Systems”. In: *The Semantic Web – ISWC 2024*. Springer Nature Switzerland, pp. 153–170. DOI: 10.1007/978-3-031-77847-6_9. URL: http://dx.doi.org/10.1007/978-3-031-77847-6_9.

Lebo, T., S. Sahoo, and D. McGuinness (2013). *PROV-O: The PROV Ontology*. W3C Recommendation, 30 April 2013. World Wide Web Consortium. URL: https://www.w3.org/TR/prov-o/.

Li, V. G., M. Dunn, P. Pearce, D. McCoy, G. M. Voelker, S. Savage, and K. Levchenko (2019). "Reading the Tea Leaves: A Comparative Analysis of Threat Intelligence". In: *28th USENIX Security Symposium (USENIX Security 19)*. USENIX Association. URL: https://www.usenix.org/conference/usenixsecurity19/presentation/li.

Liu, Z., Z. Sun, J. Chen, Y. Zhou, T. Yang, H. Yang, and J. Liu (2020). "STIX-based Network Security Knowledge Graph Ontology Modeling Method". In: *Proceedings of the 2020 3rd International Conference on Geoinformatics and Data Analysis*. ICGDA 2020. ACM, pp. 152–157. DOI: 10.1145/3397056.3397083. URL: http://dx.doi.org/10.1145/3397056.3397083.

Mavroeidis, V., R. Hohimer, T. Casey, and A. Jesang (2021). "Threat Actor Type Inference and Characterization within Cyber Threat Intelligence". In: *2021 13th International Conference on Cyber Conflict (CyCon)*. IEEE, pp. 327–352. DOI: 10.23919/cycon51939.2021.9468305. URL: http://dx.doi.org/10.23919/cycon51939.2021.9468305.

McCoy, C., R. Gore, M. L. Nelson, and M. C. Weigle (2024). *A Relevance Model for Threat-Centric Ranking of Cybersecurity Vulnerabilities*. Preprint. arXiv: 2406.05933.

Meier, R., C. Scherrer, D. Gugelmann, V. Lenders, and L. Vanbever (2018). "FeedRank: A tamper- resistant method for the ranking of cyber threat intelligence feeds". In: *2018 10th International Conference on Cyber Conflict (CyCon)*. IEEE, pp. 321–344. DOI: 10.23919/cycon.2018.8405024. URL: http://dx.doi.org/10.23919/CYCON.2018.8405024.

Noy, N. F. and D. L. McGuinness (2001). *Ontology Development 101: A Guide to Creating Your First Ontology*. Tech. rep. KSL-01-05. Stanford Knowledge Systems Laboratory.

Page, M. J., J. E. McKenzie, P. M. Bossuyt, et al. (2021). "The PRISMA 2020 statement: an updated guideline for reporting systematic reviews". In: *BMJ*, n71. DOI: 10.1136/bmj.n71. URL: http://dx.doi.org/10.1136/bmj.n71.

Parente, F., E. B. Rodrigues, and C. L. Mattos (2025). "FRAPE: A Framework for Risk Assessment, Prioritization and Explainability of vulnerabilities in cybersecurity". In: *Journal of Information Security and Applications* 89, p. 103971. DOI: 10.1016/j.jisa.2025.103971. URL: http://dx.doi.org/10.1016/j.jisa.2025.103971.

Poveda-Villalón, M., A. Gómez-Pérez, and M. C. Suárez-Figueroa (2014). "OOPS! (OntOlogy Pitfall Scanner!): An On-line Tool for Ontology Evaluation". In: *Interna-*

tional Journal on Semantic Web and Information Systems 10.2, pp. 7–34. DOI: 10.4018/ijswis.2014040102. URL: http://dx.doi.org/10.4018/ijswis.2014040102.

Ren, Y., Y. Xiao, Y. Zhou, Z. Zhang, and Z. Tian (2023). "CSKG4APT: A Cybersecurity Knowledge Graph for Advanced Persistent Threat Organization Attribution". In: *IEEE Transactions on Knowledge and Data Engineering* 35.6, pp. 5695–5709. DOI: 10.1109/tkde.2022.3175719. URL: http://dx.doi.org/10.1109/tkde.2022.3175719.

Ruohonen, J. (2019). "A look at the time delays in CVSS vulnerability scoring". In: *Applied Computing and Informatics* 15.2, pp. 129–135. DOI: 10.1016/j.aci.2017.12.002. URL: http://dx.doi.org/10.1016/j.aci.2017.12.002.

Ruohonen, S., A. Kirichenko, D. Komashinskiy, and M. Pogosova (2024). "Instrumenting OpenCTI with a Capability for Attack Attribution Support". In: *Forensic Sciences* 4.1, pp. 12–23. DOI: 10.3390/forensicsci4010002. URL: http://dx.doi.org/10.3390/forensicsci4010002.

Samtani, S., Y. Chai, and H. Chen (2022). "Linking Exploits from the Dark Web to Known Vulnerabilities for Proactive Cyber Threat Intelligence: An Attention-based Deep Structured Semantic Model". In: *MIS Quarterly* 46.2, pp. 911–946. DOI: 10.25300/misq/2022/15392. URL: http://dx.doi.org/10.25300/misq/2022/15392.

Sarhan, I. and M. Spruit (2021). "Open-CyKG: An Open Cyber Threat Intelligence Knowledge Graph". In: *Knowledge-Based Systems* 233, p. 107524. DOI: 10.1016/j.knosys.2021.107524. URL: http://dx.doi.org/10.1016/j.knosys.2021.107524.

Schlette, D., F. Böhm, M. Caselli, and G. Pernul (2020). "Measuring and visualizing cyber threat intelligence quality". In: *International Journal of Information Security* 20.1, pp. 21–38. DOI: 10.1007/s10207-020-00490-y. URL: http://dx.doi.org/10.1007/s10207-020-00490-y.

Scott, L. and J. Cohen (2025). "A Novel Vulnerability Prioritization Model for Workstation Endpoints with Context Intelligence". In: *2025 IEEE International Carnahan Conference on Security Technology (ICCST)*. IEEE, pp. 1–6. DOI: 10.1109/iccst63435.2025.11293920. URL: http://dx.doi.org/10.1109/iccst63435.2025.11293920.

SEPSES Team (2024). *ICS-SEC KG: Repository, Ontology, and RML Mappings*. Commit terakhir 7 Juni 2024; diakses 9 Oktober 2026. URL: https://github.com/sepses/ics-sec-kg.

Shimizu, N. and M. Hashimoto (2026). "Vulnerability Management Chaining: An Integrated Framework for Efficient Cybersecurity Risk Prioritization". In: *IEEE Access* 14, pp. 31407–31424. DOI: 10.1109/access.2026.3665768. URL: http://dx.doi.org/10.1109/access.2026.3665768.

Sikos, L. F. (2023). “Cybersecurity knowledge graphs”. In: *Knowledge and Information Systems* 65.9, pp. 3511–3531. DOI: 10.1007/s10115-023-01860-3. URL: http://dx.doi.org/10.1007/s10115-023-01860-3.

Spring, J. M., E. Hatleback, A. Householder, A. Manion, and D. Shick (2019). *Prioritizing Vulnerability Response: A Stakeholder-Specific Vulnerability Categorization*. White paper. Software Engineering Institute, Carnegie Mellon University. URL: https://apps.dtic.mil/sti/html/tr/AD1088910/index.html.

Tounsi, W. and H. Rais (2018). “A survey on technical threat intelligence in the age of sophisticated cyber attacks”. In: *Computers & Security* 72, pp. 212–233. DOI: 10.1016/j.cose.2017.09.001. URL: http://dx.doi.org/10.1016/j.cose.2017.09.001.

Valletta, F., G. Longo, E. Russo, and A. Merlo (2026). *TRACE-CTI: Auditable Post-Extraction Governance of TTP Claims with Knowledge Graphs*. Preprint. arXiv: 2607.24563.

W3C OWL Working Group (2012). *OWL 2 Web Ontology Language Document Overview (Second Edition)*. W3C Recommendation, 11 December 2012. World Wide Web Consortium. URL: https://www.w3.org/TR/owl2-overview/.

Zeng, Z., D. Huang, G. Xue, Y. Deng, N. Vadnere, and L. Xie (2024). “ILLATION: Improving Vulnerability Risk Prioritization by Learning From Network”. In: *IEEE Transactions on Dependable and Secure Computing* 21.4, pp. 1890–1901. DOI: 10.1109/tdsc.2023.3294433. URL: http://dx.doi.org/10.1109/TDSC.2023.3294433.

Zhao, X., R. Jiang, Y. Han, A. Li, and Z. Peng (2024). “A survey on cybersecurity knowledge graph construction”. In: *Computers & Security* 136, p. 103524. DOI: 10.1016/j.cose.2023.103524. URL: http://dx.doi.org/10.1016/j.cose.2023.103524.

Zhao, X., L. Qi, Y. Zhang, Y. Guan, G. Yang, Y. Lu, and X. Wang (2026). “Debapt: Ontology-driven multi-agent debate for APT adversary profile construction from cyber threat intelligence”. In: *Computers & Security* 170, p. 104988. DOI: 10.1016/j.cose.2026.104988. URL: http://dx.doi.org/10.1016/j.cose.2026.104988.

Zibak, A., C. Sauerwein, and A. C. Simpson (2022). “Threat Intelligence Quality Dimensions for Research and Practice”. In: *Digital Threats: Research and Practice* 3.4, pp. 1–22. DOI: 10.1145/3484202. URL: http://dx.doi.org/10.1145/3484202.

LAMPIRAN A
DAFTAR KEPUTUSAN UNTUK BIMBINGAN

Tabel berikut memuat keputusan yang dibutuhkan sebelum desain dibekukan. Kolom "Usulan" adalah rekomendasi penulis. Kolom "Keputusan" diisi saat bimbingan.

No.	Pertanyaan	Usulan penulis	Keputusan
K0	Apakah pergantian topik dari atribusi APT *group* (usulan pertemuan 1) ke integrasi CTI OpenCTI–SEPSES untuk penilaian kerentanan dapat diterima?	Ya, dengan alasan: (1) atribusi APT berbasis KG sudah banyak diteliti, misalnya CSKG4APT, APT-ATT, dan atribusi berbasis graf heterogen, dengan sedikitnya enam karya pada korpus awal; (2) evaluasi atribusi membutuhkan identitas aktor yang dapat diverifikasi, padahal pada data aktor hanya dinyatakan oleh laporan dan namanya tidak seragam (misalnya lima varian Lazarus tanpa ID ATT&CK); (3) arahan pembimbing untuk menautkan *vulnerability* ke CVE/CPE SEPSES mengarah langsung ke penilaian kerentanan berbasis aset, yaitu *use case* SEPSES sendiri; (4) konteks aktor tetap dipakai (CQ3–CQ4)	
K1	Apakah masalah tunggal (integrasi CTI OpenCTI ke SEPSES yang benar, dapat ditelusuri, dan sadar waktu) sudah tepat sebagai fokus tesis?	Ya. Alternatif yang dipertimbangkan (ranking berbasis ancaman; agregasi bukti sadar ketergantungan sumber) dijadikan *future work*	
K2	Apakah satu RQ dengan tiga ukuran (U1 kebenaran, U2 waktu, U3 *provenance*) memadai?	Ya; U4 coverage dan U5 kegunaan sebagai pendukung	

No.	Pertanyaan	Usulan penulis	Keputusan
K3	Pola *provenance*: RDF-star seperti ICS-SEC atau *named graph* per laporan?	RDF-star bila didukung triplestore target, demi keselarasan dengan ICS-SEC; *named graph* sebagai alternatif. Prototipe v0.1 memakai *named graph* di Fuseki. Triplestore apa yang dipakai di lingkungan SEPSES/lab (Fuseki atau Virtuoso)?	
K4	Implementasi pemetaan: memperluas pipeline Java/RML SEPSES atau Python (lanjutan pekerjaan pendahuluan)?	Memperluas `cat-json.rml` bila hasil diharapkan masuk ekosistem SEPSES	
K5	Versi kosakata SEPSES mana yang menjadi target, dan bagaimana status endpoint/dump TU Wien?	Pin ke commit repositori ICS-SEC; memakai dump/seed lokal	
K6	Cukupkah satu *feed* OpenCTI (AlienVault 2025), atau perlu konektor lain (misalnya ATT&CK, KEV) atau tahun lain?	Satu *feed* untuk tesis; tambahan dicatat sebagai batasan	
K7	Apakah profil aset skenario (instansi pemerintah dan perguruan tinggi) dapat diterima sebagai pengganti CMDB nyata?	Ya, dengan pernyataan batasan yang eksplisit	
K8	Ambang evaluasi: F1 makro $\geq 0{,}90$; 0% bukti *inadmissible*; 100% *provenance*; $\kappa \geq 0{,}80$	Dibekukan sebelum *test set* dibuka	
K9	Ukuran *gold standard*: 60 CVE (20 *dev*, 40 *test*); siapa anotator kedua?	Pembimbing atau rekan satu laboratorium	

No.	Pertanyaan	Usulan penulis	Keputusan
K10	Perlukah studi kegunaan dengan praktisi (U5), dan apakah prosedur etik diperlukan?	Opsional, 3–5 praktisi, kuesioner anonim	
K11	Apakah hasil ditargetkan menjadi modul resmi SEPSES dan *resource paper*?	Ya, bila pembimbing setuju	
K12	Perlukah keterkaitan dengan KG-RAG (CyKG-RAG/AgCyRAG) disebut sebagai *future work*?	Ya, hanya sebagai *future work*; *gold standard* CQ dapat menjadi benchmark	
K13	Judul tesis dipilih dari kandidat yang mana?	Diputuskan setelah K1–K4	
K14	Lingkup *indicator*: dikeluarkan seluruhnya, dimodelkan tanpa *observable*, atau dimodelkan dan dievaluasi kualitasnya?	Dimodelkan tanpa *observable*: kelas Indicator dan relasi `indicates` beserta `valid_until`/`revoked` dipetakan, lalu dipakai pada CQ3b (deskriptif). Alasan: sesuai arahan pertemuan 1 tentang relasi *indicator–malware*, tetapi tidak melebar ke evaluasi kualitas IOC (masalah P-E)	
K15	*Provenance* dua tingkat: selain konektor agregator (AlienVault), perlukah penerbit asli laporan (misalnya ESET, QiAnXin) dicatat?	Ya, sebagai `prov:wasDerivedFrom` ke sumber asli yang diturunkan dari `external_references`; dibutuhkan agar CQ6 terjawab penuh (temuan prototipe v0.1)	

No.	Pertanyaan	Usulan penulis	Keputusan
K16	Syarat “tidak `revoked` per t”: status `revoked` pada ekspor adalah keadaan 2026 (53,8% *indicator* berstatus dicabut), bukan keadaan pada t. Apakah OpenCTI dapat mengekspor riwayat versi objek?	Bila riwayat tidak tersedia, syarat `revoked` tidak dipakai per t dan dinyatakan sebagai batasan; aturan waktu bertumpu pada `published`, `valid_from`/ `valid_until`, dan W	

LAMPIRAN B
MATRIKS KETERLACAKAN

Tabel ini memeriksa benang merah dari indikator masalah, ke RQ, tujuan, tahap metode, dan ukuran evaluasi. Setiap baris harus dapat ditelusuri. Baris yang tidak dapat ditelusuri menandakan komponen yang semestinya dikeluarkan dari ruang lingkup.

Tabel B.1. Keterlacakan masalah–RQ–tujuan–metode–ukuran

Indikator masalah	Bagian RQ	Tujuan	Tahap metode	Ukuran
SEPSES tidak memiliki konteks ancaman; CVE CTI yang ada di SEPSES lokal hanya 36,6%	"benar"	T1 ontologi; T2 integrasi	4 ontologi; 5 transformasi dan *entity linking*	U1, U4
45,8% hubungan CVE–ancaman bocor dari masa depan (t0 = 30 Sep 2025); 51,4% usang (W = 90 hari, t0 = 31 Des 2025)	"sesuai waktu keputusan"	T2 *admissibility*	6 penalaran as-of t	U2
Jejak laporan, pembuat, dan waktu hilang pada integrasi naif	"dapat ditelusuri"	T1 PROV-O; T2 *provenance*	4–5 *provenance* dan SHACL	U3
KEV biner, CVSS statis, EPSS global: tidak menjawab relevansi ancaman bagi organisasi	"penilaian berbasis aset"	T3 tier dan studi kasus	6 tier; 10 studi kasus	U5

LAMPIRAN C
KESESUAIAN DENGAN ARAHAN BIMBINGAN PERTEMUAN 1

Tabel berikut memetakan arahan pembimbing pada pertemuan 1 (18 Juni 2026) ke bagian draft yang menjalankannya. Menit merujuk ke transkrip rekaman bimbingan (catatan BIM-01).

Arahan (menit)	**Penerapan dalam draft**	**Lokasi**
Use case dulu: apa masalahnya dan mengapa memakai KG (53:43)	Masalah nyata, ilustrasi kasus CVE-2025-8088, tiga jenis kesalahan integrasi naif, dan kebutuhan KG	Subbab 1.1, 1.2
Jangan membangun KG tanpa tahu pemakaiannya (34:16)	KG dibangun untuk menjawab CQ1–CQ8; evaluasi utama adalah ketepatan jawaban CQ	Subbab 4.5, 4.8
CQ sebagai alat *scoping* domain (40:02)	Satu RQ, delapan CQ, batasan masalah yang eksplisit	Subbab 1.3, 4.5
CQ harus konkret dengan instans data, bukan abstrak (11:36–18:46)	Contoh terapan CVE-2025-8088 dengan jawaban yang diharapkan per waktu keputusan	Subbab 4.5.1
Dari CQ disusun taksonomi, lalu kelas dan relasi (41:29–42:19)	Tahap 4 bagan alir; tabel *trace* kelas→CQ	Gambar 4.3, Tabel 4.4
Relasi adalah kunci; bedakan T-box dan A-box (17:27, 45:36)	Skema T-box dengan relasi yang teramati pada data, termasuk *indicator–malware* (`indicates`) yang dipakai CQ3b; contoh A-box	Gambar 4.5, 4.6, Tabel 4.5
Pakai ontologi SEPSES, jangan menyalin hasil ChatGPT (26:05–26:47)	*Reuse* kosakata SEPSES/ICS-SEC dan perluasan `cat-json.rml`; setiap kelas ditelusuri ke asal kosakata	Subbab 4.4
Tautkan *vulnerability* ke CVE dan CPE (09:28–11:09)	*Entity linking* STIX `vulnerability`→CVE SEPSES; CQ1 melalui CPE atau rentang versi	Subbab 4.4, Tabel 4.5
Visualisasikan pemetaan untuk memeriksa relasi (23:24, 30:49)	Tahap 5: hasil pemetaan sampel divisualisasikan sebagai graf; visualisasi A-box prototipe v0.1 dengan pilihan waktu t sudah dibuat	Subbab 4.3, 4.9.2

Arahan (menit)	**Penerapan dalam draft**	**Lokasi**
CQ diterjemahkan ke kueri SPARQL (12:55, 33:26)	Setiap CQ menjadi templat SPARQL dengan jalur relasi eksplisit; CQ1–CQ7 sudah dijalankan pada prototipe	Tabel 4.5, 4.12
CQ dikueri pada *database* (13:03)	KG prototipe disimpan di triplestore Apache Jena Fuseki (TDB2), bukan basis data graf *property graph*, agar tetap RDF/SPARQL seperti SEPSES	Subbab 4.2.3, 4.9.2
Iteratif: bila CQ tidak terjawab, ontologi diperbaiki dan diberi versi (33:40, 42:35)	Tahap 8a dan panah iterasi ke tahap 4 (ontologi v0.x)	Gambar 4.3
Gunakan sampel kecil dulu (37:21)	Prototipe v0.1 memakai 7 laporan dan 3 CVE; pengembangan berikutnya pada *dev set*	Subbab 4.9.2, 4.8
Ikuti standar komunitas secara *bottom-up* (63:47–65:40)	STIX 2.1, kosakata SEPSES, PROV-O, dan validasi SHACL	Subbab 4.4
Pendekatan berbasis pengetahuan, bukan ML (43:29–44:50)	Penalaran deterministik; kerangka *knowledge-driven*	Subbab 3.2, 4.1
LLM hanya lapisan di atas; masalah utamanya pemodelan (59:44)	LLM dan KG-RAG ditempatkan sebagai penelitian lanjutan	Subbab 1.5; Lampiran A
Pelajari proyek kelompok S1 (37:43–53:40)	Proyek diposisikan sebagai karya terkait dalam ekosistem SEPSES	Subbab 2.2
Laporan progres di grup, sebaiknya dalam bentuk GitHub (50:07–50:44)	Rencana pelaporan berkala dengan repositori GitHub	Subbab 4.11